BSV Unified Identity: Private, Verifiable, Unlinkable KYC, from BRC-100 Wallets to eIDAS

Draft v0.2 (working) Siggi (BSV Association); additional editors TBD

Contents

Part I: Framing 1
1. Executive summary 1
2. Motivation and the eIDAS window 2
3. Scope, terminology, and conformance 3
4. Design goals and principles 3
Part II: Landscape and thesis 4
5. Building blocks: the two BSV identity stacks 4
6. The unification thesis and layered architecture 6
Part III: Normative core (the proposed BRC) 7
7. Identifier layer (`did:bsv`): *Normative* 7
8. Key management and signing: *Normative* 8
9. Identity model: *Normative* 10
10. Private, verifiable, unlinkable KYC: *Normative* 11
11. Credential and attestation layer: *Normative* 16
12. KYC tiers and levels of assurance: *Normative* 17
13. Zero-knowledge toolbox: *Normative (capabilities); Informative (instantiations)* 20
14. Authentication and presentation: *Normative* 22
15. Consent, data rights, and governance: *Normative* 23
Part IV: eIDAS interoperability profile (the maturity path) 26
16. Stage 1, interop bridge: *Normative* 26
17. Stage 2, QEAA via a qTSP: *Normative* 27
18. Stage 3, notified eID scheme at LoA High: *Normative* 27
19. Format and trust interoperability: *Normative* 28
Part V: Closing 30
20. Security and privacy considerations: *Normative (requirements); Informative (analysis)* 30
21. Reference implementation and conformance: *Normative* 31
22. Comparison: *Informative* 32
23. Roadmap and phasing: *Informative* 33
24. Conclusion and appendices 34

> Working draft. Section numbering is fixed; prose is filled top-down. Conformance keywords (MUST, MUST NOT, SHOULD, SHOULD NOT, MAY) are interpreted per RFC 2119 / RFC 8174 and apply only to sections marked *Normative*.

Part I: Framing

1. Executive summary

Digital identity today rests on trusted third parties acting as gatekeepers. That makes identity data a breach honeypot, makes document forgery a standing risk, and turns every login into a tracking event because the same identifiers are reused everywhere. KYC compounds the problem: regulated services need a verified person, but the prevailing options either destroy privacy (hand over documents, then get correlated across services) or are not verifiable (self-asserted claims a relying party cannot check).

This document proposes a unified identity layer for the BSV blockchain that makes KYC **private but verifiable**. A holder proves they are a real, current, uniquely-identified person who satisfies stated

predicates (over-18, EU-resident, assurance at or above some level) without revealing who they are, and presents a *different* identifier to every relying party so that activity cannot be correlated across services, even when those services collude. One boundary is stated up front: this pattern legally serves age verification, Sybil resistance, and access gating. Where anti-money-laundering law requires customer due diligence, the obliged entity must identify the customer and retain identity data, and no predicate proof substitutes for that; there the layer offers verifiable, minimized, consented disclosure, not unlinkability (§10.9).

The layer binds existing primitives rather than inventing new ones: `did:bsv` (a UTXO-friendly DID method listed in the W3C DID extensions registry, §5.2) as the resolvable identifier; W3C Verifiable Credentials as the canonical credential and attestation format; BRC-42/43 key derivation and BRC-103 mutual authentication for keys and presentation; BRC-52/53 keyrings as an optional BSV-native selective-disclosure profile; and a zero-knowledge toolbox for predicate proofs, unlinkable pseudonyms, and proof of enrolment uniqueness (per-document at Tier 1; per-person only with accountable issuance, §10.7). Onboarding is tiered, beginning with a free, self-sovereign tier in which the holder reads their own passport chip with no issuer involved, and rising through issuer-verified and in-person tiers. The aim is to consolidate BSV's identity primitives into a single standard and raise them to national-scale, regulated use.

Two deliverables follow: (1) a new BRC specifying the binding layer normatively, and (2) an eIDAS interoperability profile defining a three-stage maturity path (interop bridge, Qualified attestation via a qualified trust service provider, and a notified eID scheme) aligned to the EU Digital Identity Wallet timeline.

2. Motivation and the eIDAS window

Centralised identity fails in three predictable ways. Aggregated identity stores are honeypots whose breach is catastrophic and irreversible. Paper and PDF credentials are forgeable and slow to verify. And because the same identifiers are presented to every service, ordinary use produces pervasive cross-service correlation and surveillance as a side effect.

KYC sharpens all three. A regulated service must establish who it is dealing with, yet the act of establishing it typically requires the user to surrender a full identity document to each counterparty, where it is stored, re-used, and exposed. The user pays in privacy; the service pays in liability. The result is a paradox: the more thoroughly identity is verified, the more widely it is leaked.

A UTXO blockchain is well suited to breaking this paradox. Transaction chains give an immutable, block-ordered, double-spend-protected sequence of events, exactly what is needed to record credential issuance, key rotation, and revocation, verifiable under SPV against the header chain, paired with an authenticated current-state proof, without trusting a central index (§7.6). BSV adds low-fee, high-throughput anchoring and fast verification (subject to the finality and availability assumptions of §7.6 and §20.6); block time provides approximate ordering, not a legally qualified electronic timestamp. `did:bsv` is already registered and resolvable, so the identifier layer need not be invented.

The regulatory window is open and dated. eIDAS 2.0 (Regulation (EU) 2024/1183) requires every EU member state to make at least one government-backed EU Digital Identity Wallet available: the first implementing regulations were published on 4 December 2024, and the regulation's 24-month clock places national wallet availability at late December 2026, with mandatory acceptance by specified private-sector relying parties (regulated sectors requiring strong authentication, and very large online platforms on user request) following roughly a year later. In practice readiness is lagging: fewer than a third of member states currently meet the readiness benchmark and several national wallets are slipping into 2027, which, if anything, widens rather than narrows the window for a standards-aligned entrant. The Architecture and Reference Framework is now maintained on a structured, iterative release cycle (v2.9.0, May 2026, at the time of writing) and continues to evolve through 2026. A BSV identity layer that is standards-aligned can interoperate with this infrastructure rather than compete with it.

The specific gap this work targets is unlinkability. The EUDI mainstream selective-disclosure formats (SD-JWT VC, mdoc) are linkable across colluding verifiers. The ARF has now taken up zero-knowledge

proof as a first-class topic (high-level requirements for ZKP and for pseudonyms sit in its Annex 2, referencing ETSI TR 119 476), but support is explicitly expected only *after* the December 2026 launch, over credentials already issued in the linkable baseline formats. So the launch ecosystem is linkable, and the live differentiator is no longer "the ARF lacks zero-knowledge" but **unlinkable-by-default, from day one, with offline (non-interactive) presentation**, the pattern in §10, delivered by the toolbox in §13. The advantage is realised on the BSV-native and zero-knowledge path; presentations made in the EU-baseline formats inherit those formats' linkability, exactly as the EU baseline does until its own ZKP track is deployed (§19.4).

3. Scope, terminology, and conformance

In scope. The binding layer (identifier, keys, credentials, presentation); the private-verifiable-unlinkable KYC pattern; the KYC tier and level-of-assurance model; the zero-knowledge toolbox; and the eIDAS interoperability profile.

Out of scope. Defining a new blockchain or a new DID method; this adopts `did:bsv`. Specifying a consumer wallet product. Mandating a single zero-knowledge proving system; the toolbox is pluggable (§13). Legal-person and organisational identity is deferred to a later profile (mirroring the EU's separate business wallet); delegation (§§9.4, 15.5) is the only organisational touchpoint in this version. When that profile is developed, organisational identity SHOULD anchor on ISO 17442 Legal Entity Identifiers (LEI) in their verifiable form (GLEIF vLEI).

Conformance. Normative sections use RFC 2119 / RFC 8174 keywords. The specification is modular: the core (identifier, keys, identity model, the KYC pattern, and presentation, §§7-14) can be adopted independently of the zero-knowledge toolbox (§13) and the eIDAS profile (Part IV), which are separable companion profiles. A conforming implementation declares which parts it implements; partial adoption of the core is valid.

Terminology (selected).

- *Holder / Subject*: the person controlling the identity and its keys.
- *Issuer*: a party asserting claims about a subject (Tier 2/3). At Tier 1 there is no third-party issuer: the credential is self-issued by the wallet, with the issuing state's document PKI (via passive authentication) as the verifiability anchor (§11.3).
- *Relying party (RP) / Verifier*: a party requesting proof.
- *qTSP*: qualified trust service provider (eIDAS).
- *Credential*: a W3C Verifiable Credential; an *attestation* is a credential.
- *Presentation secret* `s`: a high-entropy, wallet-generated value, genuinely secret and never disclosed; the source of scoped pseudonyms and holder binding (§8.4, §10).
- *Personhood nullifier* `n` *(uniKey)*: a deterministic, one-way function of a person's passport identity (Tier 1); the basis for document-anchored uniqueness: precisely, at most one active enrolment per supported document (§10.7, §12). It is **not** secret (anyone who has read the passport chip can recompute it), so it is used exactly once, at enrolment, to derive the registry uniqueness tag; no `n`-derived value ever appears in a presentation, and pseudonyms are never derivable from it (§8.4, §10.7).
- *Personhood commitment*: the credential's binding commitment to both `s` and `n` (§11.1).
- *Scoped pseudonym*: `pid = PRF(s, RP_scope)`; stable per RP, unlinkable across RPs (§10).
- *Selective disclosure*: revealing chosen fields only.
- *Predicate proof*: proving a statement about an attribute (e.g. age ≥ 18) without revealing the attribute.
- *Tier*: an onboarding assurance level (§12).
- *LoA*: eIDAS level of assurance: Low, Substantial, or High.
- *Passive authentication*: ICAO 9303 verification that a passport chip's data is genuine and unmodified, via the issuing state's signing PKI.

4. Design goals and principles

- **P1, private by default.** A holder MUST be able to satisfy an RP's requirement without revealing any attribute beyond what that requirement entails.

- **P2, verifiable.** Every claim an RP relies on MUST be cryptographically verifiable and anchored to a trust source (issuer signature, document PKI, or DID status).
- **P3, unlinkable across contexts.** Distinct RPs MUST receive uncorrelated identifiers; correlation MUST remain infeasible even if RPs collude.
- **P4, deliberate uniqueness.** Where one-account-per-person is required, the scope of the uniqueness guarantee (per-RP vs registry-wide) MUST be stated explicitly and MUST NOT be overstated: registry-wide uniqueness at Tier 1 is *one active enrolment per supported passport document, subject to registry integrity and fresh chip authentication* (§10.7, §12); per-person uniqueness requires the accountable one-credential-per-person guarantee of Tiers 2-3. It is never enforced by revealing person-derived values at presentation.
- **P5, free, self-sovereign onboarding.** A usable assurance tier MUST be reachable with no issuer dependency (self-read document, Tier 1); higher assurance adds accountable attestations.
- **P6, additive assurance.** Assurance accrues as attestations over a single persistent identity and personhood commitment, not as separate identities per tier.
- **P7, non-custodial and recoverable.** Holders control their keys by default; recovery MUST NOT require surrendering custody to a trusted third party.
- **P8, current and revocable.** Credential and key status MUST be verifiable, and status checks SHOULD NOT reveal the holder's activity to the issuer.
- **P9, standards-aligned.** The layer MUST map to W3C VC/DID, support OpenID4VC/SIOP presentation, and profile cleanly onto eIDAS/ARF, ISO/IEC 18013-5, and SD-JWT.
- **P10, reuse over reinvention.** The layer MUST build on existing BSV primitives (`did:bsv`, BRC-42/43/52/53/100/103) rather than introduce a new mechanism wherever an established one already serves.
- **P11, SPV-verifiable and scalable.** Verification paths MUST be SPV-compatible and MUST NOT require a trusted full-index intermediary as the only option.
- **P12, consent and data minimisation.** Disclosures MUST be consented; on-chain data MUST be limited to commitments and hashes, never plaintext PII, to stay compatible with data-protection erasure expectations.

Part II: Landscape and thesis

5. Building blocks: the two BSV identity stacks

BSV already carries most of the machinery an identity system needs, but it has grown as two largely separate stacks that were never designed to interlock. Naming them is the first step to binding them.

5.1 The wallet / attestation stack

This stack grew out of the BRC process around a non-custodial wallet.

- **Keys.** BRC-42 (the BSV Key Derivation Scheme, "type-42") derives per-protocol, per-counterparty keys from a root secret; BRC-43 fixes the security levels, protocol IDs, key IDs, and counterparties so derivation paths are well-defined and addressable. Every transaction output and identity proof rides on this.
- **Wallet interface.** BRC-100 is a vendor-neutral wallet-to-application API spanning action (transaction) management, key management, identity and certificate handling, and output management. It is what lets an application talk to any conforming wallet: extension, server, or library.
- **Authentication and presentation.** BRC-103 is a peer-to-peer mutual authentication and certificate-exchange protocol built on nonce challenges, BRC-42 derivation, and the BRC-100 signature mechanisms (DER-encoded ECDSA over secp256k1; BRC-103 itself is signature-scheme-agnostic and delegates to the wallet interface). It supports selective field disclosure through per-field keyrings, on-chain (UTXO outpoint) revocation, and interchangeable transports: HTTP (specified by BRC-104,

which defines the `.well-known/auth` endpoint and `x-bsv-auth` header transport for BRC-103 messages), NFC, or WebSocket.

- **Credentials.** BRC-52 defines privacy-centric identity certificates with selective revelation and UTXO-based revocation: fields are individually encrypted (BRC-2) and signed (BRC-3), and disclosed to a verifier through a keyring that is not itself part of the signature. BRC-53 added the request, creation, and revelation methods over the BRC-1 messaging layer; it is now historical as an application-to-wallet method set; current wallet certificate behaviour is specified by BRC-100 (`acquireCertificate`, `listCertificates`, `proveCertificate`, `relinquishCertificate`) with BRC-52 defining the certificate structure. This document cites BRC-52/53 for the certificate and keyring model and BRC-100 for the live interface.
- **Compliance extension.** BRC-108 binds BRC-52/53 certificates to tokens (extending the BRC-107 Mandala token) to enforce KYC/AML and identity-gated asset rules with SPV-friendly proofs, evidence that the certificate model already reaches into regulated use.

5.2 The VC / DID stack

This stack grew out of W3C self-sovereign-identity practice and was instantiated on BSV by TNG Identity.

- **Identifier.** `did:bsv` is a UTXO-friendly DID method registered in the W3C DID extensions registry, a discovery registry that the W3C explicitly does not operate as an endorsement. Its method specification and reference resolver are currently authored and operated by a single vendor (TNG / Teranode Group), a centralisation dependency deeper than the indexer question and addressed by the multi-vendor resolution requirement in §7.6. The method records DID creation, key rotation, status update, and revocation as immutable, timestamped transaction chains; uses the signatures already present in those transactions for authorisation; and supports multi-party control, for example a 1-of-2 multisig under which either the DID controller or the subject can revoke. A DID manager coordinates subject and controller signatures, and status checks are performed independently of the issuer and manager, so verifying a DID's status does not reveal the verifier's activity to the issuer.
- **Resolution.** A universal resolver validates a DID, loads its transaction history, reconstructs the current DID Document, caches it, and returns a W3C-compliant resolution result. The reference resolver loads history via WhatsOnChain; for a standards proposal this is the centralisation and latency point to address, so a Teranode/overlay-native resolution path is specified as the normative option, with WhatsOnChain as one permissible driver (§7).
- **Credentials and exchange.** W3C Verifiable Credentials and Presentations, served by an Issuer API, a Verifier API (including SIOP), a holder wallet, and an OAuth2/OIDC SSO bridge into Web2 stacks.

5.3 External standards the layer must meet

The W3C VC and DID data models; SD-JWT and ISO/IEC 18013-5 (mdoc) as the selective-disclosure credential encodings used by EUDI; OpenID4VCI and OpenID4VP, with SIOP, as the issuance and presentation protocols; and eIDAS 2.0 with its Architecture and Reference Framework (PID, QEAA, Trusted Lists, and the Low/Substantial/High levels of assurance). Remote identity proofing for the accountable tiers follows **ETSI TS 119 461 v2.1.1 (2025-02)** (with the companion survey **ETSI TR 119 460**), the reference standard bound by **Commission Implementing Regulation (EU) 2026/798** (7 April 2026) for remote onboarding of EUDI Wallet users, with levels of assurance per Implementing Regulation (EU) 2015/1502 (§12, §18). Biometric proofing additionally engages the **EU AI Act (Regulation (EU) 2024/1689)**, classified in §15.2. For assurance crosswalk and global (non-EU) alignment, the following are reference points mapped where relevant rather than dependencies: NIST SP 800-63-4 (the IAL/AAL/FAL model, §12), ICAO Digital Travel Credentials (the digital form of the eMRTD, §12), ISO/IEC 24760 (identity-management framework and vocabulary), and FIDO2/WebAuthn/CTAP (phishing-resistant authenticators, §8.8). Legal-person identity anchors on ISO 17442 LEI / GLEIF vLEI in future work (§3, §23).

5.4 BAP as prior art

The Bitcoin Attestation Protocol pioneered, on BSV, several ideas this layer carries forward: multiple unlinkable identities per person, attestation chains of trust, signing-key rotation decoupled from the funding source, consent grants and revocation, delegation of a completed KYC between identities, and the uniKey, a deterministic personhood anchor derived from NFC passport attributes (the inspiration for the personhood nullifier `n`, §8.4). BAP is treated purely as inspiration; it informed this model but is not part of the standard, and no backwards compatibility with its on-chain AIP-signed attestation format is provided. The ideas it pioneered are re-expressed natively as W3C Verifiable Credentials bound to `did:bsv`, with no `did:bap` migration path in the normative core.

6. The unification thesis and layered architecture

The two stacks of §5 solve adjacent halves of the same problem and do not currently interlock. The wallet/attestation stack has excellent keys, authenticated sessions, and selective-disclosure certificates, but no resolvable, standards-registered identifier and no native bridge to the VC and eIDAS world. The VC/DID stack has a registered identifier (`did:bsv`), W3C credentials, and OIDC/SIOP reach, but treats the wallet as an issuance and holding endpoint rather than exploiting BRC-42 derivation, BRC-103 mutual authentication, or keyring selective disclosure, and it inherits SD-JWT's cross-verifier linkability. Neither stack, on its own, delivers KYC that is at once private, verifiable, and unlinkable.

The proposal is a single binding layer, the new BRC, that sits over both stacks and composes them into one coherent system: `did:bsv` as the resolvable identity; BRC-42/43 keys and BRC-103 sessions beneath it; W3C Verifiable Credentials as the canonical credential, with BRC-52/53 keyrings as an optional BSV-native selective-disclosure profile; and a zero-knowledge toolbox that turns selective disclosure into unlinkable, predicate-bearing, uniqueness-aware presentation. The presentation edge speaks both BRC-103 and OpenID4VP/SIOP, so the same identity serves a BSV-native application and an eIDAS relying party without re-issuance.

The architecture is a stack (Figure 1). At the base, the BSV ledger (UTXO, SPV, and overlay/Teranode services) is the data registry, and type-42 key derivation (BRC-42/43) the cryptographic substrate. Above it sit the two native stacks of §5 as parallel pillars. The binding layer spans both pillars: it is where the personhood commitment, scoped pseudonyms, KYC tiers, and zero-knowledge proofs live (§§9-13). The presentation edge exposes the binding layer over BRC-103 and OpenID4VP/SIOP. At the top, the eIDAS interoperability profile (Part IV) maps the whole system onto PID, QEAA, and Trusted Lists.

Figure 1 · Layered architecture

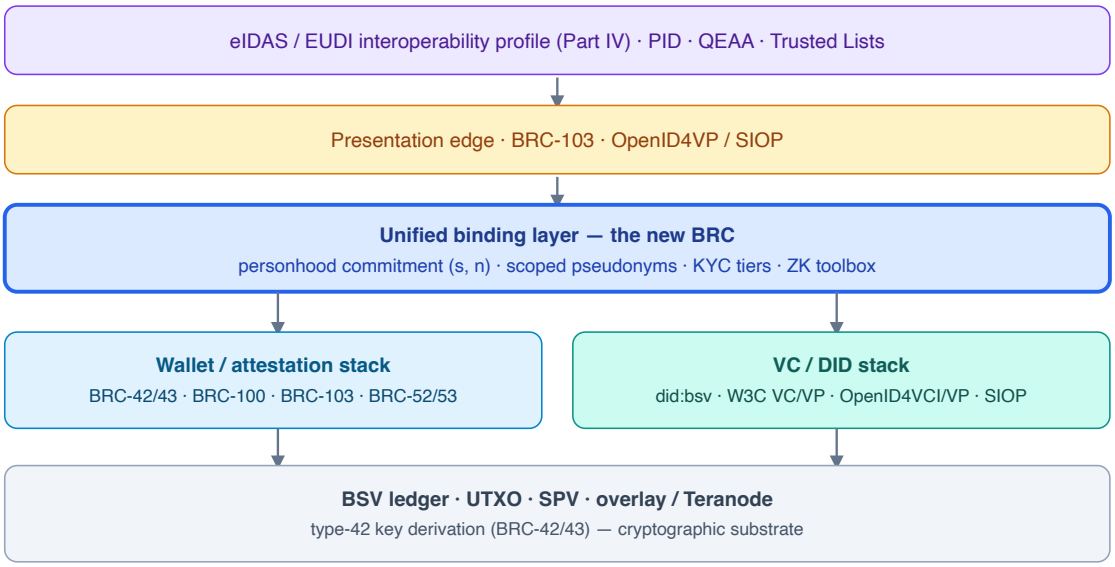


Figure 1. Layered architecture of the unified BSV identity system: the BSV ledger and type-42 derivation as foundation, the two native stacks of §5 as parallel pillars, the new binding layer spanning both, the dual-protocol presentation edge, and the eIDAS profile on top.

Part III: Normative core (the proposed BRC)

7. Identifier layer (`did:bsv`): *Normative*

This profile adopts `did:bsv` as the canonical identifier and does not redefine it; the method's identifier syntax and on-chain operations follow the registered `did:bsv` method specification. This section pins down how the binding layer uses the method and the additional requirements it places on control, status, and resolution.

7.1 Adoption. A subject's root identity MUST be a `did:bsv` DID. Its DID Document verification methods MUST be secp256k1 keys derived under §8. Implementations MUST NOT introduce a competing DID method for the root identity. This fixes the *root* identity to one method for control and recovery; interoperability with other identity ecosystems (EBSI/`did:ebsi`, national eID, other DID methods) is achieved at the **credential layer** (portable VC formats plus Trusted-List / registry trust bridging, Part IV), not by resolving `did:bsv` inside a foreign method's trust framework. Where a verifier anchors trust to a DID method or ledger it does not accept `did:bsv` from, a cross-certification or bridge issuer is required (§19.3); presenting a portable credential does not by itself make the `did:bsv` root resolvable there.

7.2 Operations. DID creation, key rotation, controller changes, and deactivation MUST be recorded as `did:bsv` transaction-chain operations. Because each operation spends the prior state, the chain is a unique, ordered, double-spend-protected, block-timestamped history of the identity, from which the current DID Document is deterministically reconstructed. Block timestamps give approximate ordering, not a qualified electronic timestamp (§7.6).

7.3 Control model. Each DID has a controller and a subject. This profile MUST support subject self-revocation via the method's 1-of-2 arrangement, under which either the controller or the subject can unilaterally **deactivate**; a DID Document **update** (including key rotation) requires both signatures (B.3). Where the controller is uncooperative, the subject's escape hatch is unilateral deactivation followed by creation of a successor DID and credential re-binding (§11.3), a heavier operation than rotation, stated here so P7 is satisfied honestly rather than by overstating what rotation alone permits. Control of the DID is independent of assurance tier: self-control (the subject is its own controller) is the default at every tier, including Tier 3. A deployment MAY name a distinct controller as an operational choice, but the subject MUST retain an independent ability to deactivate and, through the successor-DID escape hatch above, to re-establish control under keys it solely holds (P7), since a co-signed (2-of-2) update cannot be compelled from an uncooperative controller.

7.4 Key rotation and continuity. Signing keys MUST be rotatable without changing the DID. Superseded keys remain in the on-chain history with their validity window, so signatures made while a key was current stay verifiable after rotation. Rotation MUST preserve identity continuity: credentials bound to the DID remain valid, and, because scoped pseudonyms derive from the presentation secret `s` rather than from any signing key (§8.4, §10), a holder's relationships with relying parties survive key rotation and recovery unchanged.

7.5 Status and revocation. Resolution MUST return the current DID Document together with status (active / deactivated). Revocation is a deactivation operation recorded on-chain. Status determination MUST be performable by a verifier independently, without contacting the issuer or a DID manager, so that checking a DID's status does not disclose the verifier's activity (P8).

7.6 Resolution. A resolver MUST reconstruct the DID Document from the on-chain operation chain and MUST verify that chain under SPV. SPV establishes a transaction's inclusion under the header chain; it does not by itself establish that no later transaction has spent the current state, that the supplied

operation history is complete, or a legally qualified time. A resolver MUST therefore also obtain an authenticated current-state (unspent chain-tip) proof (B.5), rest on a stated data-availability assumption for discovering any later spend, and treat block time as approximate ordering evidence, not a qualified electronic timestamp; where legally qualified time is required, a qualified electronic timestamp or other accountable time source is needed. The normative resolution path MUST be available over BSV-native infrastructure (overlay services / Teranode), so that resolution does not depend on a single third-party indexer. A public indexer such as WhatsOnChain MAY be used as a resolution driver but MUST NOT be the sole trust or availability dependency. Resolution results SHOULD be cacheable, with resolution metadata expressing freshness and the block height at which status was determined.

7.7 The root DID is not a presentation identifier. The root `did:bsv` is the control and recovery anchor. It MUST NOT be presented to relying parties for routine interactions; relying parties receive per-RP pairwise identifiers (§9) instead. This rule, that the KYC'd root identity is never used directly in an application, is load-bearing for unlinkability (§10).

8. Key management and signing: *Normative*

8.1 Primitives. All **chain-layer and BRC-103 authentication** keys are secp256k1 and their signatures are DER-encoded ECDSA: Bitcoin transaction signatures (DID operations, on-chain anchors) and the BRC-103 authentication handshake alike; BRC-103 delegates signing to the BRC-100 `createSignature`/`verifySignature` mechanisms, whose documented output is DER-encoded ECDSA. (Earlier drafts described the handshake as Schnorr; that was incorrect against the published BRCs, and this profile does not define an incompatible variant.) This secp256k1 rule governs the chain and authentication layers only; it is **not** a claim that every key in the system is secp256k1. Distinct suites, each with its own versioning and migration rules, apply elsewhere: (1) BSV transaction and `did:bsv` control keys; (2) BRC-42/BRC-103 application keys, both secp256k1/ECDSA as above; (3) credential securing keys, ES256K where the key is secp256k1, or a standardized boundary cryptosuite otherwise (§11.3); (4) proof-system groups such as BLS12-381 for BBS+ and SNARK-friendly fields (§13.1); (5) EU-boundary and authenticator algorithms, P-256 FIDO authenticators (§8.8), and the mdoc/HAIP algorithm profiles of the consuming ecosystem (§5.3, §19). Implementations MUST pass the conformance test vectors (§21).

8.2 Type-42 derivation. Keys MUST be derived under BRC-42/43: each key is determined by a (security level, protocol ID, key ID, counterparty) tuple over a root secret. Using the relying party as the counterparty yields a distinct signing key per relationship, so signing keys, like pseudonyms, do not correlate across relying parties.

8.3 Hierarchy. A holder controls a single root secret, held non-custodially (P7) in a wallet or secure element. From it derive the identity root key (the `did:bsv` controller key, §7), per-counterparty presentation keys, and credential field-encryption keys (BRC-52 keyrings, §11). The root secret MUST NOT leave the holder's control and MUST NOT be escrowed with any single third party.

8.4 The personhood commitment: two values, not one. Personhood rests on two distinct values, both domain-separated from signing keys and both committed in the holder's credential (§11.1): - the *presentation secret* `s`, a high-entropy value derived from the holder's root secret under a dedicated domain separator (§8.3), so it is reproduced by the same root-secret backup that protects the signing keys (§8.6) and need not be escrowed separately; it is never disclosed, and serves as the PRF input for scoped pseudonyms (§10) and holder binding (§11.6). It is recovered through the §8.6 backup, never by re-reading a document, and because it is independent of any individual signing key, pseudonyms are stable across key rotation and recovery (§7.4). - the *personhood nullifier* `n` (the uniKey), a deterministic, one-way function of the holder's passport identity attributes at Tier 1: the document number, the MRZ fields, and the hash of the chip's Document Security Object (SOD). The SOD hash is included because it is high-entropy and readable only from the chip, so computing `n` requires having *read* the chip, not merely photographed the photo page, while contributing no biometric input: the DG2 facial-image hash used in earlier drafts is deliberately excluded, because deriving a uniqueness identifier from a facial image is special-category biometric processing (GDPR Art. 9) and adds no uniqueness beyond the document fields (§15.3). `n` anchors document-level uniqueness (§10.7), at most one active enrolment per document,

not provably one per natural person (§12), and the same passport always yields the same `n`, even from a fresh wallet. `n` is **not** a secret (anyone who has read the passport chip can recompute it), so `n`-derived values MUST NOT appear in any presentation: `n` is used exactly once, at enrolment, to derive the registry uniqueness tag (§10.7), and scoped pseudonyms MUST NOT be derivable from `n`.

Conflating the two, using a passport-derived value as the presentation secret, would let anyone who has read the holder's passport recompute their pseudonyms and forge holder binding; the separation is therefore mandatory.

8.5 Custody. The default custody model is non-custodial. Custodial deployments MAY exist for specific markets but MUST be declared to the relying party as a property of the credential, since they change the trust model, and MUST NOT be the only option offered for a given assurance tier. Declaration is a weak control on its own: convenience pressure drives real deployments toward custody, and a custodial wallet can correlate a holder across relying parties internally, defeating the §10 unlinkability guarantee even when the on-the-wire identifiers remain pairwise. A custodial deployment MUST therefore additionally disclose that the custodian can correlate the holder's pseudonyms, and the non-custodial option MUST remain the default and stay available at every tier.

8.6 Recovery. Implementations MUST support at least one recovery mechanism that does not surrender custody: M-of-N social recovery, threshold/MPC key shares, or hardware-backed backup. Higher tiers MAY additionally offer issuer-assisted re-binding, in which an accountable issuer re-attests the holder's existing personhood commitment to a fresh key set. Any recovery mechanism MUST be expressible as a controller-authorised `did:bsv` key rotation (§7.4) and MUST NOT allow a single external party to unilaterally assume control of the identity. Where recovery reconstructs the root secret from shares (M-of-N social recovery, threshold/MPC), reconstruction MUST occur inside the new device's secure boundary; shares MUST NOT be combined at a coordinator or any other single external point, since whoever momentarily holds the reconstructed root secret holds every pseudonym the holder has (§8.4).

8.7 Signing in use. Presentation signatures MUST use the per-RP derived key (BRC-42 with the relying party as counterparty); on-chain DID operations use the controller key. Where a secure element or hardware signer is available, signing keys SHOULD be generated and held there.

8.8 Authenticator binding (optional). A wallet MAY bind access to its signing keys to a FIDO2/WebAuthn authenticator (a platform secure element or roaming passkey) for phishing-resistant, hardware-backed custody, corresponding to NIST SP 800-63-4 AAL2/AAL3. Because FIDO authenticators commonly operate on P-256 rather than secp256k1, the authenticator generally gates access to the secure element that holds the secp256k1 identity keys rather than acting as the secp256k1 signer itself; where a platform authenticator does expose secp256k1, it MAY hold the signing key directly. Authenticator strength is a custody axis independent of the assurance tier (§12): it raises AAL, not the proofing level, and complements, never replaces, BRC-103/OID4VP presentation.

8.9 Multi-device. Scoped pseudonyms are deterministic in `s`, and `s` derives from the root secret (§8.4); a holder using two devices therefore keeps their relying-party relationships only if both devices derive the same `s`. Independent per-device secrets are non-conformant: they fork the holder's pseudonyms. A multi-device implementation MUST provision the same root secret to each device by secure-boundary-to-secure-boundary transfer (a wrapped transfer between secure elements, or the §8.6 threshold mechanism executed inside the new device's boundary), MUST NOT expose the root secret to any intermediary, sync service, or cloud reconstruction point, and MUST treat de-authorising a device as a key rotation (§7.4), which preserves pseudonyms by design. Where secure-element policy makes the root secret non-exportable, the conforming alternative is a designated proving device: other devices request presentations from it and never hold `s`.

8.10 Root-secret compromise and `s`-migration. Two events must not be conflated. *Loss of a device* whose secure element holds the root secret is a recovery event (§8.6): the secret is non-exportable, an authenticator gates access (§8.8), and the device's keys are individually revocable. The **authorized-device list is the set of per-device signing keys published as `verificationMethod` entries in the root DID Document** (B.2): each authorized device holds its own key derived under §8.2 and listed

there, and per-device revocation is a `did:bsv` DID Document update (§7.4, B.4) that removes or expires that device's verification method, leaving the root secret, `s`, and every pseudonym untouched (§8.4). No separate device-list artifact or schema is introduced; the mechanism reuses DID key management, and a device-list update is a 2-of-2 DID update like any other (B.3). *Exposure of the root secret itself* (extraction, provisioning-time malware, a broken secure element) is categorically different: `s` derives from it, `s` cannot be rotated without changing every pseudonym, and no key rotation makes an attacker forget a secret. This specification therefore defines the compromise path rather than claiming rotation contains it: - On suspected exposure the holder executes **`s`-migration**: generate a fresh root secret (hence `s´`), re-register the personhood commitment under the *same* uniqueness tag via the Appendix F replacement transition, and present to each relying party a one-time **pid-handover proof**: a zero-knowledge proof of knowledge of both the old `s` (opening the stored `pid = PRF(s, scope)`) and the new `s´` (with `pid´ = PRF(s´, scope)`), bound to the new credential's registry membership. The relying party replaces `pid` with `pid´`; handovers at different relying parties are mutually unlinkable, exactly as the pseudonyms are. - Handover MUST be gated on the registry replacement: knowledge of the exposed `s` alone MUST NOT suffice, or the attacker could migrate the victim's accounts to keys the attacker controls. Replacement under an existing tag is the `active` → `superseded` transition (Appendix F.3), which requires a fresh F.2 proof over the same physical document *and* proof of continuity with the incumbent registration. **This anti-theft gate holds only for documents that support Active or Chip Authentication.** For an AA/CA document the fresh chip transcript (F.2(b)) cannot be reproduced from extracted wallet data, so only the party physically holding the passport can complete migration and a wallet-compromise attacker cannot. For documents without AA/CA, which carry `uniqueness: none` and for which F.2(b) waives the chip leg (§12), the registry replacement provides **no** anti-theft gate: an attacker who extracted the wallet can reproduce the enrolment proof from the stored data groups and passive-authentication evidence (§11.3). For that document class, `s`-migration MUST instead proceed through accountable Tier-2/3 re-proofing and eviction (§12), and a deployment MUST NOT represent registry-gated `s`-migration as theft-resistant for it. Races resolve through accountable eviction (Appendix F.6). - Deployments for which any materialization of the root secret is unacceptable SHOULD use **threshold proving**: the root secret exists only as shares (across devices, or device plus service), presentations are computed by a threshold protocol, and no single device ever holds `s`. This composes with §8.6 and §8.9 and removes the exposure class at the cost of protocol complexity.

9. Identity model: *Normative*

9.1 Three levels. The model has three levels:

1. *Root personhood identity*: one `did:bsv` per person as the intended wallet model (not a protocol-enforced property: nothing prevents a person from holding multiple root DIDs, especially at Tier 0, §12), the control and recovery anchor, carrying the personhood commitment (the secret `s` and nullifier `n`, §8.4). It is never presented directly to relying parties (§7.7).
2. *Per-RP pairwise identifiers*: for each relying party, a derived, unlinkable identifier: the scoped pseudonym `pid = PRF(s, scope_RP)` together with a per-RP presentation key (§8.2). These are what relying parties see and store.
3. *Personas (optional)*: a holder MAY maintain multiple context identities (for example professional vs personal), each its own `did:bsv` able to hold its own credentials, optionally provable as sharing the same personhood commitment when uniqueness is required.

9.2 Unlinkability. Distinct relying parties MUST receive uncorrelated identifiers (P3). Pseudonym derivation MUST be one-way: from a `pid` it MUST be infeasible to recover `s`, the root DID, or any other relying party's `pid`. Cross-RP correlation MUST remain infeasible even if relying parties pool their data (§10, §13).

9.3 Uniqueness alongside unlinkability. All of a holder's pseudonyms derive from the one presentation secret `s`, while uniqueness rests on the one personhood nullifier `n` (§8.4); together they allow proof of enrolment uniqueness (at Tier 1, one active enrolment per supported document, §10.7, §12) while keeping the pseudonyms themselves unlinkable. The scope of any uniqueness guarantee, per-RP

or registry-wide, is a deliberate choice (P4) specified in §10; the identity model only requires that both be expressible.

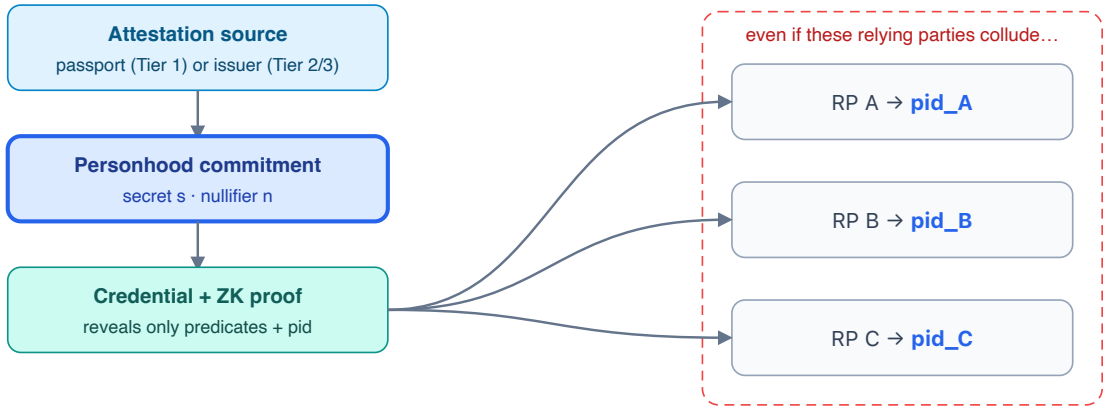
9.4 Delegation. The model MUST allow a holder to delegate presentation rights or a completed KYC to another identity, for example an organisation acting for a person, or reusing one KYC across a holder's own personas. A delegation is a signed, revocable Verifiable Credential; its governance, scope, and revocation are specified in §15.

10. Private, verifiable, unlinkable KYC: *Normative*

10.1 Goal. A holder MUST be able to satisfy a relying party that they are a real, current, appropriately-assured person who meets stated conditions, while disclosing nothing beyond those conditions and presenting an identifier that cannot be correlated with the identifier they present to any other relying party. *Private* and *verifiable* are joint requirements here, not a trade-off.

10.2 The pattern. Three elements compose it: - a *personhood commitment*: the credential's commitment to the presentation secret `s` and the personhood nullifier `n` (§8.4); `s` is generated in the wallet and never disclosed; - a *scoped pseudonym*: `pid = PRF(s, scope_RP)`, computed per relying party (§9.1); - a *presentation proof*: a zero-knowledge proof (§13) tying the pseudonym to a valid credential and to the disclosed conditions, without revealing `s`, the credential, or any undisclosed attribute.

Figure 4 · Unlinkable KYC — one person, a different identifier per service



Every presentation is verifiable; the pseudonyms stay unlinkable across services — correlation remains infeasible even under collusion.

Figure 4. The core pattern. A single personhood commitment yields a different, stable pseudonym at each relying party; every presentation is verifiable, yet no set of relying parties can correlate them.

10.3 What the proof establishes. For a relying party with scope `r`, required predicate set `P`, and minimum tier `t`, a conforming presentation proves, in zero knowledge, that the holder knows a secret `s` and a credential `C` such that: (a) `C` commits to `s` (and, where a uniqueness guarantee applies, to the personhood nullifier `n`, §10.7); (b) `C` is validly attested by a source trusted at tier ≥ `t` (§10.5); (c) `C` is current, not revoked or expired (§10.6); (d) every predicate in `P` holds over the attributes in `C`; (e) `pid = PRF(s, r)`; (f) where a uniqueness guarantee applies, `C` is an active member of the anchored enrolment registry (§10.7), proven without revealing which member; revealing to the relying party only `pid`, the truth of `P`, and the satisfied tier, and nothing else. In particular no value derived from the personhood nullifier `n` is revealed (§8.4), and `C` itself is never shown: a commitment repeated verbatim at every presentation would be a cross-scope correlation handle as damaging as a reused identifier.

10.4 What the relying party does and does not get. It gets an identifier that is *stable for it*: the same person returns the same `pid` at the same scope, so a relying party can enforce one account per returning holder locally (at Tier 1 this is one per enrolled document, not provably one per person, §10.7, §12); and *unlinkable across scopes*: another relying party's `pid` for the same person is uncorrelated, and correlation

MUST remain infeasible even under collusion (§9.2). It does not learn `s`, the root DID, the credential, the holder's other pseudonyms, or any attribute value beyond the disclosed predicates.

10.5 Attestation source and tier. The source that attests `C` MAY be a Tier-1 self-read passport (in which case (b) is satisfied by an ICAO 9303 passive-authentication signature chaining to the issuing state's CSCA, §12, and `C` is self-issued), or a Tier-2/3 issuer or qTSP. The tier MUST be a provable attribute of the proof, so a relying party can require a minimum (for example "tier ≥ 1 AND over-18") without learning anything further. Where revealing the specific attesting source would itself correlate the holder, the proof SHOULD instead prove that the source belongs to an accepted trust set (e.g. an EU Trusted List, §17) without revealing which member (§13.4).

10.6 Currency and revocation. The proof MUST bind to credential and DID status (§7.5) such that a revoked or expired credential cannot produce an accepted presentation. Status MUST be checkable by the relying party without contacting the issuer (P8); §13.5 specifies privacy-preserving revocation via non-membership in a published accumulator. DID status specifically MUST be proven the same way: the presentation carries a zero-knowledge proof, with a stated freshness bound, that the credential's root DID is bound and not deactivated (accumulator membership/non-revocation); a verifier MUST NOT resolve the root DID per presentation, since a DID that is hidden by design (§7.7) cannot simultaneously be handed to every verifier for a status lookup without becoming the very correlation handle the design prohibits. Direct resolution remains a controller, issuer, and audit operation (§7.6), not a presentation-path one.

The mechanism, reusing the §13.5 accumulator machinery: the BSV-native overlay that resolves `did:bsv` (§7.6) maintains an **active-root-DID accumulator** whose members are commitments to currently-active (non-deactivated) root DIDs. Its root is anchored on-chain at a stated cadence and its witnesses refresh under the Appendix F.7 retrieval-privacy rules. A root DID enters the accumulator on creation and MUST be removed when a `did:bsv` deactivation operation spends its chain tip (§7.5, B.6); deactivation is the accumulator's update trigger, the DID-status analogue of the Appendix F enrolment transitions, and it applies equally to self-issued Tier-1 credentials, which have no issuer but do have a root DID. Because the personhood commitment binds the root DID's control key (§11.1), a presentation proves in zero knowledge that its committed holder key corresponds to a root DID whose commitment is a current accumulator member, without revealing which. The exact accumulator construction, the party or quorum accountable for its updates and on-chain anchoring, the witness-refresh protocol, and the accepted freshness bound are pinned in Appendix C.3 and the conformance vectors (§21.2) and are a Phase-1 work item (§23); until they are fixed, requirement 10.3(c) cannot be met privately, and a deployment MUST NOT claim private DID-status checking or rely on §7.7 DID-hiding on the presentation path.

10.7 Uniqueness scope: the deliberate choice (P4). Per-RP uniqueness, the scoped pseudonym `pid = PRF(s, r)`, gives Sybil resistance at each relying party with full cross-RP privacy and needs no shared infrastructure, because `pid` is stable for that RP yet uncorrelated across RPs. Registry-wide uniqueness rests on the personhood nullifier `n` (§8.4), which is deterministic from the passport and so survives re-enrolment with a fresh `s`, and it is enforced **at enrolment, never at presentation**. Its honest strength is stated in P4: at most one active enrolment per supported document, subject to registry integrity (Appendix F) and fresh chip authentication (§12). Two admissible mechanisms:

- *(i) Registry-enforced (Tier 1).* Enrolment submits a registration record (the blinded commitment `C`, the deterministic uniqueness tag `tag = PRF_n(uniqueness_dst)`, Appendix C.4, and the Layer-D enrolment proof) to the enrolment registry, a multi-party overlay function operating the Appendix F state machine. The registry admits at most **one active registration per tag** (re-enrolling the same passport with a fresh wallet collides on the tag and is rejected), and every uniqueness-bearing presentation proves registry membership (§10.3(f)) without revealing which entry. One document then backs one active credential committing to one `s`, so per-scope one-account-per-document follows from the stability of `pid` alone; nothing `n`-derived need ever be revealed to a relying party. **The tag is held off-chain.** Because it is deterministic from chip data it is treated as personal data (§15.3): it MUST be stored only by the registry operator set, access-controlled and rate-limited, MUST cease to be queryable when its registration reaches a terminal state (Appendix F.3), and MUST NOT

be written on-chain; only salted registry roots and opaque record hashes are anchored (P12; EDPB Guidelines 02/2025 on blockchain, final version, disfavour public-chain storage of re-linkable values). The residual leak, testing *whether a document has enrolled*, is thereby gated on registry query access rather than open to any chip reader. Earlier drafts instead revealed a per-presentation nullifier `PRF(n, scope)`; because `n` is chip-recomputable and `scope` public, any passport reader could compute every relying party's nullifier for the holder and join dedup records back to the real passport identity. Presentation-time `n`-derived values are therefore prohibited outright (§8.4).

- *(ii) Issuance-enforced (Tiers 2-3).* An accountable provider guarantees one credential per person at issuance, the only mechanism in this specification that supports a *per-person* claim.

A deployment MUST state which guarantee it offers, in the P4 wording, and MUST NOT describe the Tier-1 guarantee as one-per-person. A registration record MUST contain only the blinded commitment, the one-way tag, and the enrolment evidence, never identifying data (P12). Tier 1 alone provides only a self-asserted cryptographic anchor (`n` from the document), so a Tier-1 guarantee resists casual Sybil attacks but not determined impersonation with a borrowed or stolen passport; contested registrations are resolved by accountable eviction (§12, Appendix F.6).

10.8 Requirements summary. A conforming implementation MUST: derive pseudonyms with a one-way PRF (§9.2); keep cross-scope correlation infeasible under collusion; disclose no attribute beyond the requested predicates; carry the tier as a provable attribute; bind every presentation to credential/DID status; never expose the root DID (§7.7); never reveal an `n`-derived value or the commitment `C` at presentation (§8.4, §10.3); and limit any on-chain footprint to blinded commitments, revocation handles, and salted enrolment-registry roots with opaque record hashes, never the uniqueness tag itself (§10.7, §15.3).

10.9 Regulatory scope of the pattern (informative). The §10 pattern, predicate proof plus unlinkable pseudonym, legally serves age verification, Sybil resistance, and access gating. It does not, by itself, satisfy anti-money-laundering customer due diligence: under the EU AML framework (the 2024 AML Regulation package and its predecessors), an obliged entity must *identify* the customer and *retain* identity data (name, date of birth, and more), not merely receive a predicate, however sound the cryptography behind it. For AML-regulated onboarding, the layer's contribution is the full-disclosure mode (§14.3): verifiable, minimized, consented disclosure with strong provenance. The honest claim there is *minimized and verifiable*, not *unlinkable*. Deployments MUST NOT represent a predicate-only presentation as fulfilling customer-due-diligence obligations. Full disclosure at every obliged entity, however, recreates the honeypot this design exists to remove; §10.10 defines an optional profile that closes that gap: the obliged entity holds a verifiable proof of due diligence and a sealed retrieval right, while an accredited custodian holds the identity record.

10.10 Delegated CDD custody: *Normative (optional profile).* A third presentation pattern between predicate-only (§10.3) and full disclosure (§14.3): the relying party with the legal CDD obligation (the *company*) never holds the plaintext identity record, only pseudonymous references, which remain personal data under GDPR; a regulated *custodian* holds the customer-due-diligence record; the company holds a verifiable attestation of due diligence, a cryptographic anchor to the record, and a holder-granted retrieval right exercisable on lawful triggers. Every building block is already in this specification: attestation over the existing commitment `s` (§11.3), delegation as a signed revocable credential (§15.5), private status checks (§10.6), issuer-set privacy (§13.4), and consent receipts (§15.1); this section fixes how they compose. Adoption is optional; a deployment implementing it MUST implement all of it.

Actors and accreditation. The custodian MUST be a Tier-2/3 accredited issuer under the §15.6 trust framework, carrying the distinct accreditation class **CDD custodian**. qTSP status alone is **not** sufficient authorization: a qTSP is supervised for qualified *trust services*, which is not the same as authorization to perform CDD, ongoing monitoring, sanctions screening, or AML record custody. A CDD custodian MUST therefore additionally be subject to AML supervision in its own right, or act as the company's processor under a lawful AML-Regulation Article 18 outsourcing arrangement, with sector- and country-specific approval. Ultimate CDD responsibility remains with the company under both reliance and outsourcing

regimes and cannot be contracted away; the profile changes where the record physically lives, not who answers for it.

Artifacts. - *Identity record `R`*: the full CDD file (verified attributes, document evidence, passive-authentication record, screening results, risk rating). `R` exists only at the custodian and MUST be encrypted at rest under a split key (below). - *Per-relationship anchor*: `anchor_RP = Commit(digest(R); salt_RP)` and an opaque locator `ref_RP = PRF(k_rec, scope_RP)`, where `k_rec` is a record key established at enrolment (C.6). Both MUST be derived per relying party: an anchor handed verbatim to every company would be exactly the cross-scope correlation handle §10.3 prohibits for the credential commitment. With per-RP derivation each company holds a different, uncorrelatable pointer to the same record, and only the custodian can resolve any of them. - *CDD attestation*: a credential issued by the custodian over the holder's *existing* commitment `s` (§11.3, so no identity fork), carrying: the satisfied tier, the jurisdiction whose CDD rules were applied, screening status, and the record-schema version. Status-anchored per §11.5. - *Retrieval grant*: a holder-signed, scope-limited, revocable delegation credential (§15.5, schema in C.6) authorizing the custodian to release `R` to this relationship's counterparty (identified by the company's verifier key, never by the holder's `pid`) when a defined lawful trigger occurs (regulatory demand, SAR escalation, or the company's statutory record-production duty). The grant is delivered to and held by the **company**; it MUST NOT be registered with the custodian at issuance. The custodian therefore does not learn where the holder onboards at presentation time, preserving the §15.4 property that an issuer observes neither presentations nor status checks, and learns of a relationship only if retrieval is actually invoked, which is inherently and acceptably a linking event. - *Consent receipt*: per §15.1, recording the arrangement, with the lawful-basis override of §15.3 encoded rather than implied.

Phase 1, enrolment. The holder performs a one-time full-disclosure presentation (§14.3) to the custodian. The custodian verifies at Tier 2/3, runs screening, assembles and encrypts `R`, establishes `k_rec` with the holder's wallet, and issues the CDD attestation over the existing `s`.

Phase 2, onboarding. At the company, the holder presents the §10.3 proof extended with: (b′) the attestation was issued by a member of the accepted custodian set, proven without naming the custodian (§13.4), a real privacy gain since custodian choice is itself correlatable, together with the fresh `anchor_RP`, `ref_RP`, and the retrieval grant. The company stores `pid`, the proof transcript, the anchor, the locator, the grant, and the consent receipt. Its entire customer file is **pseudonymous, not anonymous**: it holds no plaintext identity record, so a breach yields pseudonyms and opaque pointers the attacker cannot resolve, but `pid`, the anchor, the locator, and the retrieval capability remain personal data in the company's hands under GDPR (§15.3, §15.4), and under AMLR Article 18 the custodian's processing is treated as part of the company's obliged-entity CDD, for which the company stays fully liable. One honest limit: the grant's envelope must name the custodian (endpoint and key) so the company can route a lawful retrieval, so the custodian is hidden from the verifiable transcript and from anyone the company shows it to, not from the company itself; custodian-oblivious retrieval via relay is an open extension.

Phase 3, monitoring. Ongoing sanctions/PEP rescreening happens where the data lives, but rescreening MUST NOT require opening the full record `R` (which needs the 2-of-3 reconstruction below), or the split-key breach model collapses. The custodian rescreens against a **minimal screening projection** (only the identifiers screening actually needs: name, date of birth, nationality, and any sanctions/PEP list keys) held for monitoring under the custodian's own key, separate from `R`. A deployment that cannot maintain a separate screening projection MUST instead use scheduled reconstruction under independent, audited authorization, or a certified trusted execution environment; it MUST NOT give the custodian standing unilateral access to `R`. On a hit, record expiry, or SLA breach, the custodian flips the attestation status; the company's periodic private status check (§10.6, §13.5) surfaces the flag without the custodian learning who checked. The status flag MUST be **generic** (e.g. `review-required`) and MUST NOT encode a screening or SAR reason, so status alone cannot tip off the customer (Phase 4). The company then escalates by invoking Phase 4 or exiting the customer.

Phase 4, retrieval. On a lawful trigger, the company opens a mutually authenticated BRC-103 session with the custodian and presents `ref_RP`, the retrieval grant, and evidence of the trigger basis. The custodian MUST verify the grant's signature chain against the enrolment binding (C.6) and the trigger

evidence before resolving `ref_RP → R`, releasing the record, with `salt_RP`, to the company or directly to the authority. Whether grant *status* gates release depends on the trigger: a holder's revocation blocks a **voluntary** release but MUST NOT block a disclosure the law compels (§15.5). The decision table is normative:

Trigger	Grant active	Grant revoked / suspended / expired
Voluntary (holder-initiated access, ordinary access)	release	refuse
Compulsory (`regulatory-demand`, `statutory-production`, `sar-escalation` / FIU)	release	**release**; grant status cannot defeat a legally compelled disclosure; recorded to the confidential regulatory audit log (below)

The recipient MUST verify `Open(anchor_RP, R, salt_RP)`; a mismatch is a custodian-integrity event. This gives the supervisor something conventional outsourced KYC cannot: cryptographic proof the record was neither altered nor substituted since the diligence was performed. **Logging is split to avoid tipping off.** Every disclosure MUST be recorded for audit, but a disclosure on a SAR/STR- or FIU-related trigger (`sar-escalation`, or any FIU report) MUST be written **only** to a separate confidential regulatory audit log held by the obliged entity, and MUST NOT be appended to the holder-visible consent receipt or surfaced to the holder's wallet: telling the customer that money-laundering analysis or FIU reporting is or may be under way is prohibited (AMLR Article 73). Only non-tipping-off events (the holder's own access, or an ordinary trigger the law does not require kept confidential) MAY be appended to the consent receipt. Any log entry MAY be hash-anchored on-chain for non-repudiation (P12).

Key splitting: don't move the honeypot, split it. The custodian is a concentration risk by construction. `R` MUST be encrypted such that no single party, including the custodian, can decrypt unilaterally. The reference construction is a 2-of-3 split of the per-record key between the custodian, the company (a wrapped share delivered inside the onboarding presentation), and a supervised escrow: a custodian breach yields ciphertext, a company breach yields a key share pointing at nothing, and legitimate retrieval reconstructs. This also mechanically prevents the custodian from browsing its own vault.

Custodian continuity. The company's statutory "immediate access on request" MUST survive custodian failure. A conforming deployment MUST provide at least one of: encrypted-record escrow retrievable with the company's share plus the escrow share; a supervised wind-down transferring vaults to a successor CDD custodian; or contractual arrangements whose breach is itself an attestation-status event (Phase 3).

Legal variants (informative, jurisdiction-gated). The EU AML framework offers two hooks, and they are not interchangeable. Under **third-party reliance**, the company conventionally receives the identifying minimum dataset immediately, with document copies on request; that variant supports *minimized disclosure plus anchor*, not zero-PII. The zero-PII form fits an **outsourcing/agency arrangement**: the custodian acts as the company's processor, `R` legally forms part of the company's CDD file while physically held at the custodian, and the guaranteed immediate retrieval right (grant + anchor + continuity provisions) is what satisfies retention and production obligations. Whether a national supervisor accepts anchor-plus-guaranteed-retrieval as "holding" the record MUST be confirmed with counsel per jurisdiction; the profile supports both variants, with the disclosed attribute set a declared deployment parameter.

11. Credential and attestation layer: *Normative*

Figure 3 · Credential lifecycle

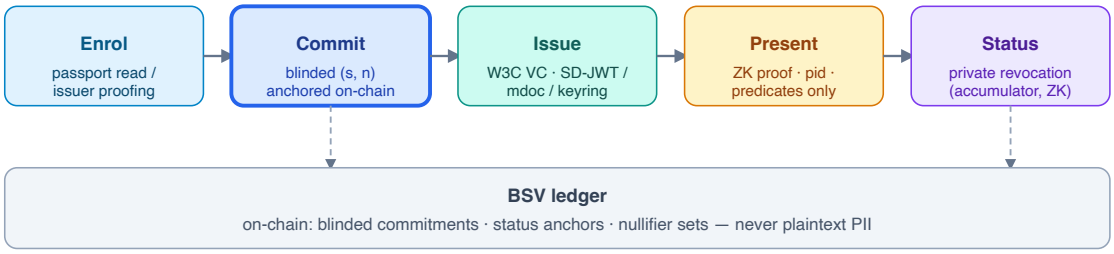


Figure 3. Credential lifecycle. Enrolment binds the personhood commitment; issuance produces a W3C VC (issuable in SD-JWT / mdoc / keyring encodings by multi-format issuance, each signed in its own right, §19.1, never signature-preserving export); presentation is a zero-knowledge proof revealing only a pseudonym and predicates; status is checked privately. Only blinded commitments and status anchors touch the chain.

11.1 Canonical format. The canonical credential and attestation type is the W3C Verifiable Credential; an *attestation* is a VC. A credential MUST commit to the holder's presentation secret `s` and personhood nullifier `n` (§8.4) and MUST be cryptographically bound to a holder key derived from the root identity (§8.2), so that only the holder can present it; this key/control binding, not embedding the DID string, is what "bound to `did:bsv`" means throughout this document. The credential MUST NOT require the resolvable root `did:bsv` to be exposed at presentation (§7.7); a verifier identifies the subject only through a scoped pseudonym derived at presentation (§10), never through the root identifier.

11.2 Data model. Claims SHOULD use established vocabularies (W3C / schema.org). Each attribute MUST be individually addressable so it can be selectively disclosed, or proven by predicate, without revealing its neighbours. Every credential carries, as verifiable metadata: its tier / level of assurance (§12), its attesting source, a validity period, a status/revocation pointer (11.5), and the single blinded commitment to `s` and `n` (C.4).

11.3 Self-issued and issuer-issued credentials. Two issuance modes correspond to the tiers (§12): - *Self-issued (Tier 1).* The wallet packages the genuine passport data groups together with their ICAO 9303 passive-authentication evidence into a self-issued VC and commits `s`. One W3C-model point MUST be kept straight: the VC's `evidence` property is *not* a securing mechanism; the data model explicitly separates evidence from proof. The self-issued credential's securing mechanism is the holder's own signature: an enveloping **VC-JOSE-COSE** proof using **ES256K** (ECDSA over secp256k1, the holder key of §8.1). A Data Integrity proof is *not* usable here: the standardized W3C Data Integrity ECDSA cryptosuites (`ecdsa-rdfc-2019`, `ecdsa-jcs-2019`, `ecdsa-sd-2023`) are defined only for P-256/P-384, and no standardized Data Integrity cryptosuite covers secp256k1, so this profile fixes the enveloping ES256K JOSE proof as the securing mechanism for any credential secured under a secp256k1 key (self-issued Tier-1, and Tier-2/3 issuers whose signing key is their `did:bsv` key). The holder's signature attests only that the holder assembled the credential; the *assurance* comes from the verifier (or the Layer-D circuit) independently re-validating the passive-authentication chain carried in `evidence`. A verifier MUST NOT treat the holder's proof as attesting the attribute values; it MUST validate the evidence chain or a zero-knowledge proof over it (§13 Layer D). Its limitations are those of Tier 1: authentic document, self-asserted holder binding, no issuer revocation. - *Issuer-issued (Tier 2/3).* An accountable issuer or qTSP issues a signed VC (for example over OpenID4VCI). An issuer MAY attest over the holder's *existing* commitment `s` rather than mint a fresh identity, so an upgrade adds assurance without forking the holder's identity (P6).

11.4 Selective-disclosure encodings. A credential MUST be expressible in at least one selective-disclosure encoding. The layer defines three interoperable profiles: SD-JWT (EUDI interop; linkable, §13 Layer A); ISO/IEC 18013-5 mdoc (mDL-style and proximity use); and BRC-52/53 keyrings (the BSV-native profile: per-field encryption with keyring revelation and UTXO-outpoint revocation). Where a

use requires §10 unlinkability, the credential MUST additionally be issuable in a form compatible with §13 Layer C/D (e.g. a BBS+ credential, or a commitment a SNARK can consume); SD-JWT alone MUST NOT be relied on where unlinkability is required.

11.5 Status, revocation, and source trust. A credential's status MUST be checkable by a verifier privately, without contacting the issuer (§10.6), via a `did:bsv` status operation (§7.5) and/or non-membership in a published revocation accumulator (§13.5). For issuer-issued credentials the attesting source is itself identified by a `did:bsv` and trusted through accreditation (Trusted Lists, §17); a presentation SHOULD be able to prove the source belongs to an accepted set without naming it (§13.4). Self-issued Tier 1 credentials have no issuer revocation; reliance is limited to document validity, expiry, and any published lost/stolen signals, consistent with the Tier 1 assurance ceiling (§12).

11.6 Holder binding and non-transferability. A credential MUST be non-transferable: presentation MUST require proof of control of the holder key and/or knowledge of `s`, so that a copied credential cannot be presented by another party.

11.7 On-chain footprint. Only commitments, status anchors, and revocation accumulators are written on-chain; credential contents and any PII remain off-chain in the holder's custody (P11, P12).

12. KYC tiers and levels of assurance: *Normative*

Identity in this system is anchored to a single persistent `did:bsv` (§7). From Tier 1 upward it also carries a persistent **personhood commitment** (to the wallet-held presentation secret `s` and the passport-derived personhood nullifier `n`, §8.4) over which assurance then accrues as additive attestations. A holder MAY begin at any tier and upgrade; the `did:bsv` and, once established, the commitment persist across upgrades, so scoped pseudonyms and existing relationships remain stable when assurance increases. A credential's tier MUST be expressible as a verifiable attribute, so that a relying party can require a minimum tier (§13) without learning anything further.

Figure 2 · Tier progression — assurance accrues over one identity

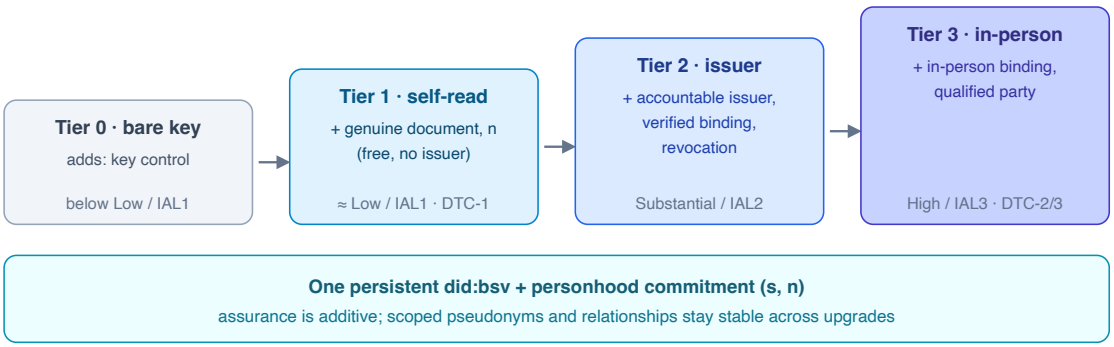


Figure 2. Tiers are additive over a single persistent identity. A holder may start anywhere and upgrade; the rising boxes denote increasing assurance, while the base bar denotes the one identity and commitment that persist throughout.

A central principle separates two ideas that are routinely conflated: **cryptographic authenticity is not identity assurance level.** A self-read passport can yield data that is provably genuine and provably from an un-cloned chip, yet still sit at the lowest assurance level, because no accountable party has verified that the person presenting it is its rightful holder.

Tier 0, bare identity key. A self-generated BRC identity key (a `did:bsv` controlled by a BRC-42-derived key, §§7-8) with no document check and no personhood commitment. It proves only control of the key, i.e. continuity of the same pseudonymous actor, not who that actor is. Optional control proofs over an email address or phone number MAY be recorded, but these are not identity proofing and do not raise the tier. *Assurance:* below eIDAS Low (no identity proofing). Use: pseudonymous and key-based login, throwaway sessions.

Tier 1, self-read document (free). The holder scans the passport Machine Readable Zone (MRZ) to derive the chip access key (PACE, with BAC fallback), reads the NFC chip, and the wallet performs ICAO 9303 **passive authentication**, verifying the Document Security Object signature and the data-group hashes against the issuing state's Country Signing CA via the ICAO Public Key Directory. The wallet MUST perform active or chip authentication wherever a Tier-1 uniqueness or personhood guarantee is relied upon, because passive authentication alone does not detect a cloned chip and cloning would defeat the uniqueness anchor `n` (§§8.4, 10.7); it SHOULD perform it in all cases, and MAY perform an on-device liveness and face match against the chip's facial image (DG2), which never leaves the device (§15.2), but this optional Tier-1 check has no certified presentation-attack detection, is defeated by a deepfake or replay, and MUST NOT be surfaced or logged to a relying party as identity verification; it is a self-asserted convenience only (§20.8). Because a substantial share of circulating passports, notably including US passports, implement neither active nor chip authentication, a deployment MUST publish a per-document-type capability matrix and define its behaviour where AA/CA is unavailable: register the document *without* a uniqueness guarantee (marked in the credential's assurance metadata), or decline Tier-1 uniqueness for that document class. Silently downgrading is prohibited. From the genuine attributes the wallet derives the personhood nullifier `n` (the uniKey), deterministic over the document number, MRZ fields, and SOD hash, with no biometric input (§8.4), which anchors uniqueness, and separately generates a fresh, high-entropy presentation secret `s` held only in the wallet (§8.4). The trust anchor is the issuing state's document PKI; there is no third-party issuer, which is what makes the tier free. *Proves:* the document data is authentic and the chip is genuine. *Does not prove:* that the presenter is the rightful holder (self-liveness, if performed, remains self-asserted), nor that the document has not been revoked or reported lost/stolen; passive authentication proves issuance integrity, not present status. A deployment claiming any currency property MUST name its lost/stolen signal, in practice INTERPOL's SLTD database (access is gated through national authorities, so most Tier-1 deployments will have none), and absent one MUST claim only "authentic at read time". *Assurance:* comparable to eIDAS **Low** in document-authenticity terms, but not a formal eIDAS level absent an accountable provider. Use: commerce, age-gating, and unique-account / Sybil resistance.

Tier-1 property	Holds?
Genuine passport document	Yes
Genuine chip, resisting copied data / emulation (with active / chip authentication; assumes chip-key non-extractability and no relay)	Yes
Unique per document	Yes
Verified that the presenter is the rightful holder	No
Accountable issuer / regulatory KYC	No

Tier 1 establishes *what the document is*, never *who is holding it*. The chip guarantee is conditional (F.2(b)): it assumes the chip's authentication key is non-extractable and that the read is not relayed from a remote genuine chip, and it resists copied data and emulation rather than proving the chip is unconditionally un-cloned.

Tier-1 enrolment, normatively. Tier 1 has no issuer, so enrolment MUST be *verifiable without trusting an attester*: the wallet submits a registration record (the blinded commitment §11.1, the uniqueness tag §10.7, and the Layer-D enrolment proof §13.2, with statement components in Appendix F.2) to the enrolment registry, whose multi-party operator set verifies the proof against the published document-PKI trust root and executes the Appendix F state machine. Because the tag is personal data held off-chain (§10.7, §15.3), verifiability is *registry-and-auditor-grade rather than universal*: the operator set and accredited auditors can re-verify every registration, and anyone can verify the anchored root history and operator quorum signatures, but the raw records are not world-readable. No trusted single enrolment service is introduced: no operator can admit a registration without a valid proof, and any operator can prove another's misbehaviour from the log (Appendix F.5). Three obligations follow. - *Trust-root governance.* In-circuit passive authentication verifies against an accepted DSC/CSCA certificate set, expressed

as a published root (in practice a Merkle root over accepted certificates). A deployment MUST specify who curates that root, its update cadence, and its on-chain anchoring, noting that ICAO PKD access is paid-membership and CSCA master-list coverage is incomplete, so accepted-set coverage, not circuit performance, gates real-world availability. The curator SHOULD be a multi-party overlay function, not a single vendor. - *Contested registrations.* A stolen or pre-read passport can be enrolled by the wrong party before the rightful holder, and Tier 1 cannot adjudicate rightful holding (§20.8). A Tier-2/3 accountable proofing event over the same document MUST therefore be able to **evict** a Tier-1 registration for the same tag and install the verified holder's commitment; the evicted party's relying-party relationships (keyed to its own `s`) do not transfer. - *Registration-time correlation.* The registration transaction's timing and funding are a linkage surface between the holder's wallet and their enrolment; deployments SHOULD mitigate with batched anchoring windows, randomized submission delay, and third-party broadcast.

Tier 2, issuer-verified. A trusted Issuer or qTSP performs identity proofing (a supervised or remote document read with liveness binding carried out by an accountable party) and issues a signed credential, and/or attests to the holder's existing personhood commitment. For remote proofing the operative EU standard is **ETSI TS 119 461 v2.1.1 (2025-02)**: passive authentication, chip/active authentication, a 1:1 face match against the chip's DG2 image, certified presentation-attack detection (ISO/IEC 30107-3), injection-attack detection, and a retained audit trail, assessed by a conformity-assessment body or national scheme (e.g. BSI TR-03147). Unlike the Tier-1 self-read, this biometric and liveness processing is performed by the accountable proofing service, not on-device (§15.2). This adds an accountable issuer and a verified holder-to-document binding, and supports issuer-side revocation and freshness. *Assurance:* targets eIDAS **Substantial**, and reaches **High** *without physical presence* where the remote flow layers additional procedures on a substantial-level eID means so the combination meets the LoA-high requirements of Implementing Regulation (EU) 2015/1502, per **CIR (EU) 2026/798** (§18.1).

Tier 3, in-person verified. Identity proofing is performed in physical presence (or a supervised equivalent) by an accountable, ideally qualified, party. This gives the strongest holder binding and is the route toward a notified eID scheme and Qualified attestations. *Assurance:* targets eIDAS **High**. In-person proofing is *one* route to High: since CIR (EU) 2026/798 (7 April 2026) a reinforced *remote* onboarding (a substantial-level eID means plus additional ETSI TS 119 461 v2.1.1 procedures, at Tier 2) reaches High as well, so High is no longer exclusively an in-person / Tier-3 property (§18.1).

Tier	Who vouches	Holder binding	≈ eIDAS LoA (indic.)	Typical use
0, bare identity key	self (key only)	none	(none)	pseudonymous / key-based login
1, self-read document	issuing state's document PKI	self-asserted	Low	commerce, age-gating, Sybil resistance
2, issuer-verified	accountable issuer / qTSP	verified remotely	Substantial (⟶ High via reinforced remote, CIR 2026/798)	regulated services, finance onboarding
3, in-person	accountable / qualified party	verified in person	High	high-value, notified eID, Qualified attestations

Two consequences. First, a relying party requires a **minimum** tier as a predicate (for example, "tier ≥ 1 AND over-18"), proven in zero knowledge (§13) without disclosing surplus attributes. Second, on uniqueness: Tier 1 can bootstrap registry-wide **per-document** uniqueness through the personhood nullifier `n` (§8.4), at most one active enrolment per supported document (P4, §10.7), but its holder binding is self-asserted, so a Tier-1 guarantee resists casual Sybil attacks rather than determined impersonation with a borrowed or stolen passport, and it is not a per-person claim (§12 passport lifecycle). Tiers 2 and 3 add accountable binding, and only they support one-credential-per-person.

Assurance crosswalk. The tier is a *proofing* level; mapped across frameworks:

This spec	eIDAS LoA	NIST 800-63-4 IAL (proofing)	ICAO DTC analogue
Tier 0	below Low	IAL1 (no proofing)	(none)
Tier 1, self-read	≈ Low (informal)	≈ IAL1, document-authentic, self-asserted binding	DTC Type 1-analogous (eMRTD-bound, holder-generated; not an ICAO DTC unless the DTC-1 structure is implemented)
Tier 2, issuer-verified	Substantial	IAL2 (remote, accountable)	DTC Type 2 (issuer-generated)
Tier 3, in-person	High	IAL3 (in-person / supervised)	DTC Type 2/3

NIST SP 800-63-4 deliberately separates proofing (IAL) from authenticator strength (AAL, §8.8) and federation (FAL, §14.6); only IAL maps to the tier, which is why custody and presentation mode are independent axes: a Tier-1 holder on a FIDO secure element is IAL1/AAL2. ISO/IEC 24760 supplies the identity-management vocabulary: its *partial identity* is this spec's persona / scoped pseudonym (§9). ISO/IEC 29115 is the older single-ordinal assurance model that both eIDAS LoA and NIST xAL supersede, and which the authenticity-vs-assurance split above deliberately moves beyond; it is a background reference only. eIDAS remains the regulatory target (Part IV).

ICAO DTC alignment. The passport tiers map onto ICAO's Digital Travel Credential framework. A Tier-1 self-read is **analogous to a DTC Type 1 derivation flow**: the virtual component is generated by the holder from the eMRTD chip, with the passport booklet as the physical component, and ICAO treats a DTC-1 as deriving its authority from the passport-issuing authority. But the self-issued W3C VC of §11.3 is **not**, by itself, an ICAO DTC: DTC-1 has a defined ICAO data structure and validation model, and an arbitrary VC carrying passport evidence does not become a DTC merely by containing that evidence. To claim DTC status (rather than analogy), a deployment MUST implement the actual ICAO DTC-1 data structure and validation requirements; otherwise it MUST describe Tier 1 as *DTC-1-analogous*, not as a DTC. Tier-2/3 issuer generation corresponds analogously to **DTC Type 2** (issuer-built, device-bound) and, where no physical book is carried, **Type 3**. Implemented to the ICAO structure, this gives the passport path a sanctioned international standard and a migration route into government-issued DTCs and border use (§16).

Passport lifecycle: what `n` anchors. The nullifier `n` is derived from chip data, and eMRTDs carry no reliable cross-document person identifier, so `n` is *per-document, not per-person*: renewing or replacing a passport yields a new document number and therefore a new `n`, and a lawful second document (dual citizenship, or a replacement issued before expiry) yields a second valid `n`. Tier-1 global uniqueness is therefore one-account-per-passport-document, not strictly one-per-person, the precise sense in which it resists casual but not determined Sybil behaviour (§10.7). This does not disturb a holder's relationships: per-RP pseudonyms derive from the wallet-held secret `s` (§8.4), so renewing a passport leaves every existing `pid` intact and only the global-uniqueness anchor `n` resets. On renewal the holder re-enrols under the new document's tag (§10.7); the superseded registration SHOULD be retired at its document's expiry, bounding the window in which one person lawfully holds two active Tier-1 registrations. Collapsing multiple documents to one person is exactly the accountable binding that Tiers 2-3 add.

13. Zero-knowledge toolbox: *Normative (capabilities); Informative (instantiations)*

13.1 The separation that makes this feasible on BSV. The chain layer (DID operations, key derivation, signing, §§7-8) is fixed to secp256k1 by BSV. The credential and proof layer is *not* bound to that curve: a presentation proof may use whatever group its proof system requires. Pairing-based schemes (BBS+ on BLS12-381) and SNARK-friendly constructions therefore run in the credential layer while identity and control stay anchored on secp256k1. Conformance requires the *capabilities* in 13.2; named instantiations are illustrative and the toolbox is deliberately pluggable (§3).

13.2 Capability layers (the full menu, ordered by maturity).

- *Layer A, selective disclosure (available now, secp256k1-native).* Reveal chosen fields, hide the rest. Instantiations: BRC-52/53 keyrings (BSV-native) and SD-JWT (EUDI interop). It hides unselected fields but reveals selected values in clear and shows a reusable issuer signature, so it is linkable across presentations: sufficient where linkability is acceptable, insufficient for §10.
- *Layer B, attribute predicates (near-term, secp256k1-native).* Prove statements about hidden attributes (age ≥ 18, residency ∈ set) without revealing the value. Instantiation: Pedersen commitments with Bulletproof range / set-membership proofs, which need no trusted setup and run natively on secp256k1. The open problem it must solve, binding the committed attribute to the attestation without a linkable signature, is addressed in 13.3.
- *Layer C, unlinkable presentation (medium-term).* Multi-show unlinkable selective disclosure: each presentation is uncorrelated even to the same verifier. Instantiation: BBS+ credentials on a pairing-friendly curve (BLS12-381), aligning with the EUDI/ARF direction; or a fresh per-presentation SNARK proving possession of a valid credential. This is the layer that delivers §10 unlinkability for disclosed attributes.
- *Layer D, predicate + unlinkability + personhood (medium-term, SNARK-based).* A single succinct proof of the full §10 statement: a credential is validly attested, predicates hold, and `pid = PRF(s, scope)` for a committed `s`. Instantiation: a zk-SNARK/STARK with a SNARK-friendly PRF (e.g. Poseidon) for the nullifier and, for Tier-1 self-read credentials, a circuit that verifies the ICAO 9303 passive-authentication signature chain in-circuit, yielding a private "genuine passport, predicates hold, nullifier `pid`" proof. This is the cryptographic engine of free, private, verifiable KYC, following the emerging class of zero-knowledge passport circuits.

13.3 The binding problem. The central task is proving that a hidden attribute is the one an accountable source attested, without showing a reusable signature (which would be a linkage handle). Three admissible strategies: (a) *Issuer-side commitment*: the source signs a Pedersen/Poseidon commitment to the attribute; the holder proves predicates over the commitment and, with Layer C/D, never shows the signature. (b) *Signature-in-circuit*: verify the source's ECDSA/Schnorr (or, for Tier 1, the passport's) signature inside the proof. Schnorr over secp256k1 is materially cheaper in-circuit than ECDSA and SHOULD be preferred where the source signature scheme is a free choice. (c) *ZK-native credential signature*: issue under a scheme built for unlinkable proof of possession (BBS+ / PS signatures); the credential-layer curve then differs from secp256k1 by design (13.1).

13.4 Issuer-set privacy. Where naming the attesting source would itself correlate the holder, a proof SHOULD support proving the source's membership in an accepted trust set (e.g. an EU Trusted List, §17) without revealing which member.

13.5 Revocation, privately. Status (§7.5, §10.6) MUST be checkable without the issuer learning of the check. Instantiation: maintain credential/nullifier revocation as a published accumulator (on-chain or overlay) and prove non-membership in zero knowledge. The published set MUST contain only opaque revocation handles or nullifiers, never identifying data (P12).

13.6 Proving-system trade-offs (informative). Bulletproofs: no trusted setup, good for ranges, no native multi-show unlinkability. Groth16: tiny proofs, fast verification, per-circuit trusted setup. PLONK / Halo2: universal or no setup, larger proofs. STARKs: transparent and post-quantum, largest proofs. BBS+: native unlinkable multi-show, requires pairings, predicates only via extensions. A deployment selects per use case; the binding layer fixes the interfaces and statements (10.3), not the proving system.

13.7 Where proofs are verified. Presentation proofs are verified off-chain by the relying party. BSV anchors commitments, credential status/revocation, and, for registry-wide per-document uniqueness, the enrolment registry's salted root history (§10.7); the registration records themselves, including the uniqueness tag, are held off-chain by the registry operator set (§10.7, §15.3). On-chain data MUST remain limited to blinded commitments, hashes, salted registry roots, and opaque record hashes (P11, P12); the deterministic uniqueness tag, or any keyless/unsalted transform of it, MUST NOT be written on-chain; no proof or attribute is required to be verified in Bitcoin script.

13.8 Feasibility and performance (informative). The layers differ sharply in cost, and a deployment MUST NOT treat them as uniformly available. One distinction governs every maturity statement below: *library maturity* is not *EUDI-integration maturity*: the EU's own TS4 specification on ZKP holds that no evaluated approach is yet mature enough for direct EUDI Wallet integration (§19.4), so the assessments here describe what ships in this layer's own ecosystem, not EU conformance. - *Layers A-B (selective disclosure, predicates)* are production-ready and cheap on mobile: keyring / SD-JWT disclosure and Bulletproof range / set-membership proofs run in milliseconds to low seconds with sub-kilobyte to low-kilobyte proofs and no trusted setup. - *Layer C (multi-show unlinkable)* via BBS+ is available in current libraries with millisecond proving. - *Layer D (full passive-auth-in-circuit)* is the expensive case. The dominant cost is verifying the issuer's signature chain (the Document Security Object signature, RSA-2048 or ECDSA, and its link to the CSCA) inside the circuit; naive RSA-2048 verification runs to millions of constraints. It is nonetheless shippable on commodity phones today, and production systems (e.g. ZKPassport, Self, OpenPassport, Rarimo) generate ICAO proofs on-device, but proving takes seconds to tens of seconds, not interactive-instant, and demands real engineering. - *Amortisation is mandatory in practice.* The heavy passive-auth proof SHOULD be run **once at enrolment**, binding the passport to the published personhood commitment (§8.4) and a registration entry; subsequent presentations then prove cheap membership against that registration plus the requested predicates and the scoped-pseudonym PRF, which are Layer-A/B-class costs. Re-proving the passport on every presentation SHOULD be avoided. - *Heterogeneity is a real cost.* States sign with different algorithms and key sizes (RSA, ECDSA, DSA, EdDSA; some legacy SHA-1), so a conforming Tier-1 circuit suite must cover several signature profiles; issuer coverage, not single-circuit speed, is the practical gating factor. - *Proving location.* On-device proving preserves privacy; remote/server proving is faster but reveals inputs to the prover and MUST NOT be used for Tier-1 self-read, whose privacy depends on local generation. Concrete circuit sizes, proof/verify times per device class, and the registration-versus-presentation split are conformance-suite deliverables (§21), not assumed here.

14. Authentication and presentation: *Normative*

14.1 Two protocols, one identity. A conforming wallet MUST support both presentation protocols: BRC-103 for BSV-native peer-to-peer mutual authentication and certificate exchange (ECDSA handshake per §8.1, over HTTP, NFC, or WebSocket), and OpenID4VP with SIOP for the W3C/eIDAS world. The same identity and credentials serve both; only the presentation envelope differs, and no re-issuance is required to move between them.

14.2 Presentation request. A relying party states what it needs (the required predicate set `P`, the minimum tier `t`, and whether unlinkability is required) as a presentation request (DIF Presentation Exchange / OpenID4VP query, or a BRC-103 certificate request). The presentation scope is **not** part of the request: `scope_RP` MUST be derived by the wallet, never accepted from the caller. A relying party that could choose its own scope string could collude with another to share one and receive identical `pid`s, defeating unlinkability by construction, since verifier identity is not otherwise an input to `pid = PRF(s, scope)`. Normatively: the wallet MUST compute `scope_RP = H_dst(canonical authenticated RP identifier)`, where the identifier is a stable identity the relying party authenticates during the §14.5 handshake: its `did:bsv` for BRC-103, or the registered client identifier under its trust scheme for OpenID4VP. **No §15.6 accreditation is required to be a relying party:** an ordinary RP proves control of its own `did:bsv` in the handshake, and because each RP's `did:bsv` is self-authenticating and distinct, per-RP uniqueness needs no shared registry (§10.7); §15.6 governs who may *attest* (issuers, certifiers, CDD custodians), not who may *request* a presentation. The wallet MUST reject a request whose asserted identity does not match the authenticated one, and MUST key the scope to that stable identifier, not to the RP's current keys, so RP key rotation does not silently re-scope pseudonyms. Two distinct relying parties thus present two distinct authenticated identities and receive uncorrelated `pid`s; the only way to share a scope is to present the *same* authenticated identity, i.e. to be cryptographically the same entity. Deliberate scope sharing across legal entities (a corporate group operating one user base) is permitted only as a declared *sector scope*: a set of `did:bsv` identities bound to one scope key by a signed, wallet-authenticatable group declaration, disclosed to the holder at consent time (§15.1). The wallet then

computes the scoped pseudonym and the zero-knowledge presentation proof (§10, §13) that satisfies the request with the minimum disclosure consistent with it (P1).

14.3 Varying detail. Disclosure granularity is set by the request and ranges over: a bare pseudonymous login (Tier 0 key control only, §12); a predicate-only proof (e.g. over-18, no identity revealed); a delegated-custody onboarding in which the relying party receives no attribute values at all, only a due-diligence attestation, anchor, and retrieval grant (§10.10); and full attribute disclosure where the holder consents (e.g. regulated onboarding revealing name and date of birth). The wallet MUST default to the least disclosure that satisfies the request and MUST obtain holder consent for each disclosure (§15).

14.4 Channels and replay protection. Presentations run over web (same-device redirect or cross-device QR / deep link), WebSocket or HTTP (BRC-103 over BRC-104), and NFC for in-person/proximity use (mdoc proximity or BRC-103 over NFC). Every presentation proof MUST be bound to a fresh verifier-supplied challenge (nonce), and the transport MUST be mutually authenticated. The challenge MUST be single-use, time-boxed, and **derived from a transcript that pins the presentation scope, the verifier's identity, and the holder's per-RP presentation key** (for BRC-103, the session identity keys; for OpenID4VP, the protocol's native binding mechanisms: `client_id`, `nonce`, audience-bound response, signed request object or verifier attestation, and response-URI binding; OpenID4VP does not define generic TLS channel binding and none is assumed). A bare random nonce prevents replay to the same verifier but not relay: without transcript binding, a malicious application holding a victim's valid proof can present it over its own authenticated session, so the party proving must be cryptographically the party authenticated.

14.5 Mutual authentication and anti-phishing. BRC-103 authenticates the relying party to the holder as well as the holder to the relying party. Before any disclosure, the wallet MUST show the holder the verifier's identity and accreditation and the exact attributes or predicates requested, so the holder can refuse an over-broad or unaccredited request (§15.1).

14.6 Sessions and SSO without a correlation honeypot. After a successful presentation a relying party MAY open a session keyed to the scoped pseudonym. SSO is supported through the SIOP / OIDC bridge, but it MUST NOT become a central correlation point: the identifier exposed to each relying party MUST be the pairwise scoped pseudonym (§9.1), and the design MUST prevent any intermediary from correlating a holder across relying parties beyond what the holder explicitly consents to. Self-issued (SIOP) presentation or direct relying-party verification SHOULD be preferred over a hosted identity provider that observes every login; where a hosted bridge is used, it MUST NOT retain cross-RP correlation data.

15. Consent, data rights, and governance: *Normative*

15.1 Holder authorization and consent. Every disclosure requires explicit, informed, per-disclosure **holder authorization**. This is a wallet-UX and data-minimisation requirement (the holder sees and approves each disclosure and MUST be able to decline), and it MUST NOT be conflated with GDPR Article 6(1)(a) *consent* as the relying party's lawful basis: the recipient's processing may instead rest on contract, legal obligation, legitimate interests, or a public task (§15.3, C.5), and statutory (e.g. AML) processing continues regardless of any optional consent. Before disclosing, the wallet MUST present the verifier's identity, the attributes or predicates requested, the stated purpose, and any retention period. The wallet MUST keep a consent record (a consent receipt) of what was shared, with whom, and when, recording the holder's approval **separately from** the relying party's actual lawful basis (C.5); this receipt MAY be hash-anchored on-chain for non-repudiation without recording its contents (P12).

15.2 Data minimisation and purpose limitation. Requests MUST be satisfiable with the minimum disclosure; relying parties SHOULD request predicates rather than attribute values wherever a predicate suffices (e.g. over-18 rather than date of birth). A wallet MAY warn the holder of, or refuse, a request broader than its stated purpose. Biometric matching **in the Tier-1 self-read** (the optional on-device liveness/face check, §12) MUST be performed on-device only, and that biometric data MUST NOT leave the holder's device. This on-device constraint is specific to the self-sovereign Tier-1 flow; it does **not** govern Tier-2/3 accountable proofing, which, under ETSI TS 119 461 v2.1.1 (§12), necessarily processes

the face match, presentation-attack detection, and injection-attack detection at the accountable proofing service, under that service's own LoA-high controls, retention schedule, and Article 9 basis. On-device processing is a safeguard, not a dispensation: where biometric data is used to uniquely identify a person, GDPR requires both an Article 6 lawful basis and an Article 9(2) condition (in this self-sovereign context, ordinarily explicit consent), and a deployment performing the optional face match MUST document both.

EU AI Act (Regulation (EU) 2024/1689). Biometric processing here is engineered to stay in the Act's lower-risk lane, and a deployment MUST keep it there. The Tier-2/3 proofing face match is **1:1 biometric *verification*** (confirming the holder is the person the document describes), which Recital 15 and Annex III(1) expressly **exclude** from the high-risk category reserved for *remote biometric identification* (1:N matching of many people, typically without their active involvement). Uniqueness in this design is anchored on the document-derived nullifier `n`, **not** on biometric 1:N matching (§8.4), so the enrolment registry performs no biometric identification. Two limits follow and are normative: a deployment MUST NOT add 1:N biometric identification (e.g. face-dedup against a gallery) or **biometric categorisation by sensitive traits** (Article 5 prohibits the latter outright) without accepting the high-risk or prohibited status that triggers; and where any AI system nonetheless falls in Annex III, its obligations (risk management, human oversight, event logging, accuracy and non-discrimination/bias testing, technical documentation, post-market monitoring) bind the proofing provider. Each deployment MUST classify its biometric components under the Act and record the result alongside the GDPR analysis above. The purely cryptographic presentation path (§10, §14) uses no biometric AI and is outside the Act's scope.

15.3 Erasure versus immutability. On-chain data MUST be limited to commitments, hashes, status anchors, and nullifiers, never plaintext PII (P12). Personal data lives off-chain: in the holder's wallet, and in a relying party's store only after a consented disclosure. This is designed to support the argument that the chain's immutability does not conflict with the right to erasure: erasure operates on the off-chain copies, while the on-chain commitments are salted, one-way, and openable only with the holder's secret. Whether such commitments are "personal data" is a contested legal question: the EDPB and national authorities have argued that a hash of personal data can remain personal data where it is re-linkable, so this position MUST be confirmed with data-protection counsel and rests on the high-entropy blinding required in §20.4. One value is deterministic by construction and needs its own analysis: the enrolment-registry uniqueness tag (§10.7) is unsalted because that determinism is what enforces one-registration-per-document. It is re-linkable by a party holding chip data and is therefore treated as personal data; the EDPB's Guidelines 02/2025 on blockchain (final version, July 2026) apply the re-linkability reasoning to hashes and similar pseudonymous values and disfavour public-chain storage of such data unless necessary. The tag is accordingly **never written on-chain**: it is held off-chain by the multi-party registry operator set, access-controlled and rate-limited, and ceases to be queryable when the registration reaches a terminal state (Appendix F.3), giving it an ordinary erasable-data lifecycle, while only salted roots and opaque record hashes are anchored. A deployment MUST still carry the tag, the registry, and any on-chain anchoring in a data-protection impact assessment covering rights handling, international transfers, and the **necessity and proportionality of a public permissionless chain for each anchored object** (including whether a permissioned alternative would suffice, and which transaction metadata (funding, broadcaster, timing) could single out a holder), per those guidelines, rather than subsuming them under the salted-commitment argument. (Design rationale, not legal advice.) Withdrawal of consent MUST be supported: when a holder revokes a consent grant, the relying party MUST cease the consent-based processing, delete the disclosed data *where consent was the lawful basis and no other basis or Article 17(3) exception applies*, and the corresponding credential or grant status MUST be updatable so the withdrawal is verifiable (§13.5). Consent is not the only lawful basis this architecture serves (C.5): contract, legal obligation, and legitimate interests are equally available under Article 6, and erasure follows Article 17′s grounds and exceptions rather than a blanket delete-on-withdrawal rule. The canonical override is statutory retention, AML record-keeping under §10.10, where withdrawal blocks any *new* voluntary use but does not defeat compelled disclosure or retention during the legally mandated window (typically five years past the relationship's end). The consent receipt MUST record the actual lawful basis and any

override explicitly; promising the holder an erasure right they legally do not have is worse than stating the limit.

15.4 Data-protection roles. Controllership is a question of fact (who determines the purposes and means of processing), not a label this specification can assign categorically. The *starting points* in self-sovereign use: the holder processes data in their own wallet largely within the household exemption; a relying party becomes controller of data it receives upon disclosure; an issuer is controller or processor for issuance data only. But a deployment MUST perform an actor-by-actor controller / joint-controller / processor analysis, including wallet providers, recovery and threshold-share providers, registry operators and trust-root curators (§10.7, §12, Appendix F), overlay services, transaction broadcasters, CDD custodians (§10.10), and potentially node operators (on which the EDPB blockchain guidelines take a broad view), together with an international-transfer analysis for any actor outside the EEA. The architecture minimises issuer exposure: an issuer does not observe presentations or status checks (§7.5), so it cannot build a profile of where the holder uses their credentials.

15.5 Delegation and power of attorney. A delegation or power of attorney (§9.4) is expressed as a signed, scope-limited, revocable Verifiable Credential, for example granting a named party authority over a defined domain (finance, real-estate, business, family, or general) for a bounded period. Delegated authority MUST be presentable with the same privacy properties as any other credential, and its revocation MUST be effective and verifiable (§13.5). One limit is legal, not technical: a delegation credential is cryptographic *evidence of an asserted mandate*, not automatically a legally effective power of attorney; legal effect depends on jurisdiction, subject matter, formality requirements (some acts require notarisation or a qualified electronic signature), and revocation-notice rules. A deployment relying on delegations for legally significant acts MUST validate those requirements per jurisdiction and MUST NOT represent the credential alone as conferring authority.

One delegation type is profiled normatively: the **CDD retrieval grant** (§10.10, schema C.6). It is signed by the holder's enrolment-bound grant key, never the root DID (§7.7), and names its audience by the company's verifier key rather than any holder identifier, enumerates its lawful triggers, and carries a resolution capability sealed to the custodian. Its revocation semantics differ from ordinary delegations by exactly the §15.3 override: holder revocation MUST block any new voluntary release and MUST be verifiable by the custodian at retrieval time, but does not defeat compelled disclosure or statutory retention during the mandated window, and the grant document MUST say so on its face.

15.6 Governance of the trust framework. Accreditation of issuers and certifiers (who may attest at which tier, and how that accreditation is published, audited, and revoked) MUST be governed by a defined trust framework. The framework MUST distinguish accreditation classes where the role differs materially; **CDD custodian** (§10.10) is one such class, since holding regulated identity records under split-key custody is a different undertaking, with different supervision, than attesting. For the regulated path this maps onto eIDAS Trusted Lists and qTSP supervision (§17). For the BSV-native path, the accredited-issuer registry SHOULD be maintained as an overlay-discoverable, on-chain-anchored list whose entries are themselves `did:bsv` identities, so that accreditation status is resolvable and revocable by the same mechanisms as any other credential.

15.7 Data-subject rights (operational). A deployment claiming GDPR alignment MUST define, actor by actor (§15.4), which party exposes each data-subject-rights interface and how it operates over off-chain and distributed state: Articles 13/14 notices, Article 15 access, Article 16 rectification, Article 18 restriction, Article 20 portability, Article 21 objection, and Article 22 (automated decisions / human review). It MUST also specify: how a rights request is authenticated **without exposing the root DID** (§7.7), for example via a scope-limited proof of control rather than DID resolution; how erasure reaches backups and replicas, not only the primary store; breach handling under Articles 33/34; and, where applicable, DPO designation and records-of-processing. A standards proposal need not reproduce the GDPR, but a compliance claim requires these interfaces to be assigned, not assumed.

15.8 Minors and age assurance. Age verification is a headline use case (§10.9, §12) and will routinely involve children, so a deployment offering it MUST address, in a dedicated profile: the applicable national

age-of-digital-consent where consent is the basis; guardian authority and child-appropriate notices; data minimisation for failed or underage presentations (no surplus retention); avoidance of any persistent underage-status or denial identifier that could follow the child; and relevant platform, audiovisual-media, gambling, and national age-assurance rules. The unlinkable predicate pattern (over-18 without identity) is well suited to this, but the minimisation and no-persistent-identifier obligations MUST be met explicitly, not assumed from the cryptography.

Part IV: eIDAS interoperability profile (the maturity path)

Figure 5 · eIDAS maturity path



Figure 5. The three-stage eIDAS maturity path. Each stage is independently useful and has an explicit exit gate; ambition and political dependency rise left to right.

16. Stage 1, interop bridge: *Normative*

The least-ambitious, fastest stage: the BSV identity layer interoperates with the EUDI ecosystem without claiming qualified status. For travel and border use, Tier-1 credentials are additionally expressible as ICAO DTC Type 1 (§12), so one identity serves both eIDAS relying parties and DTC verifiers.

16.1 Two bridge roles. A deployment MAY act as either or both: - *Relying party.* A BSV-native service accepts EUDI Wallet presentations (PID, QEAA, or EAA) over OID4VP and verifies them against EU trust anchors. To do so it MUST register with a Member State Registrar and obtain an access certificate that EUDI Wallet Units use to authenticate it. - *Non-qualified attribute provider.* The layer issues attributes consumable by EUDI wallets as non-qualified EAAs. It MUST register as a non-qualified EAA Provider and SHOULD publish an attestation rulebook in the EU catalogue so relying parties can interpret its attributes.

16.2 Format and protocol at the boundary. Three layers MUST be kept distinct at the EU boundary, because they do not say the same thing (§19.1): the **binding implementing acts**, whose format baseline is ISO/IEC 18013-5 and the W3C Verifiable Credentials Data Model 1.1 (CIR 2024/2977 Annex; CIR 2024/2979 Annex II) with multi-format issuance per CIR 2024/2982; the **ARF/HAIP profile**, which additionally specifies SD-JWT VC and evolves on its own release cycle; and this layer's **internal canonical model** (W3C VCDM 2.0, §11). A conforming bridge issues and presents in the encodings its counterparty's applicable layer requires (OID4VCI/OID4VP under HAIP where the counterparty is HAIP-conformant), and MUST NOT treat the ARF profile's format choices as legal requirements or vice versa. The BSV-native BRC-103 and keyring path (§14) is used only inside the BSV ecosystem.

16.3 Trust direction. At Stage 1 the layer trusts EU anchors to consume EU credentials, and asks EU relying parties to trust it only at the non-qualified level. It issues no PID and makes no qualified claim.

16.4 What it buys and what it does not. Immediate two-way interoperability with the EUDI ecosystem; but BSV-issued attributes carry only non-qualified weight in the EU, and unlinkability at the boundary is bounded by the EUDI formats (§19.4).

17. Stage 2, QEAA via a qTSP: *Normative*

Mid stage: BSV-anchored attestations gain EU-wide qualified status by being issued through a Qualified Trust Service Provider.

17.1 The qualified route. A Qualified Electronic Attestation of Attributes (QEAA) is issued by a qTSP under eIDAS supervision and listed on a national Trusted List aggregated into the EU List of Trusted Lists. For a BSV-anchored attestation to be qualified, the issuing entity MUST be, or operate under, a supervised qTSP, and the attestation MUST carry the `attestation_legal_category` value `QEAA`. Where the qTSP also performs the identity proofing behind the attestation, that proofing is assessed against ETSI TS 119 461 v2.1.1 (§12).

17.2 Mapping BSV certifiers to Trusted Lists. The BSV-native accredited-issuer registry (§15.6) maps onto eIDAS Trusted Lists: an issuer that is also a qTSP appears on both, and its on-chain registry entry SHOULD reference its Trusted List entry, so a verifier can resolve qualified status by either path: the EU Trusted List or the on-chain anchor.

17.3 Lifecycle and revocation. QEAAs MUST follow the ARF revocation rules: an Attestation Status List or Attestation Revocation List per the Commission technical specifications, or short-lived attestations (validity ≤ 24 hours) such that revocation is unnecessary. The privacy-preserving accumulator of §13.5 MUST be reconciled with these, either serving as or backing the status list, or replaced by short-lived re-issuance, without weakening private status checks (§10.6).

17.4 Format. A QEAA MUST be issued in an encoding satisfying the format baseline of the binding acts (ISO/IEC 18013-5 or W3C VCDM 1.1, CIR 2024/2979 Annex II) and additionally in the ARF/HAIP profile encoding (SD-JWT VC) where the consuming ecosystem requires it. Because signatures are format-specific, this is **multi-format issuance by the qTSP** (each encoding signed in its own right, per CIR 2024/2982), never conversion of an existing signed credential (§19.1).

17.5 What it buys. EU-wide qualified recognition of BSV-anchored attributes: the chain provides the tamper-evident, privately-verifiable status substrate, while the qTSP provides the legal accountability eIDAS requires.

18. Stage 3, notified eID scheme at LoA High: *Normative*

The most ambitious stage: a BSV-based wallet is the technical vehicle of a Member State-sponsored eID scheme notified at level of assurance High and recognised for cross-border authentication.

18.1 What notification requires. A Member State notifies an eID scheme, which then undergoes peer review. LoA High requires identity proofing at the highest assurance, **either** in-person / supervised proofing (our Tier 3, §12) **or**, since **Commission Implementing Regulation (EU) 2026/798** (7 April 2026), a reinforced *remote* onboarding in which a substantial-level eID means is combined with additional remote procedures (**ETSI TS 119 461 v2.1.1**) so the whole meets the LoA-high requirements of Implementing Regulation (EU) 2015/1502, together with key protection in a certified secure cryptographic device and conformity with the EUDI Wallet certification scheme defined by the implementing acts. The remote route means a notified High-assurance scheme need not force physical presence, which materially widens the wallet's onboarding design space (§12 Tier 2).

18.2 BSV mapping. To reach Stage 3 the wallet MUST meet EUDI Wallet certification (a Wallet Secure Cryptographic Device and Wallet Unit Attestation, HAIP conformance, and the rest of the certification scheme); identity proofing MUST be at Tier 3; and the scheme MUST carry a PID issued under Member State authority by a designated PID Provider, alongside the `did:bsv` identity. At this stage the BSV layer operates as part of a notified national scheme rather than as an independent provider.

18.3 Assurance mapping. Tier 0 sits below Low; Tier 1 is comparable to Low (informally, see §12); Tier 2 targets Substantial; Tier 3 targets High. A notified scheme carrying PID at LoA High corresponds to Tier 3 for in-person proofing, or to a CIR 2026/798-reinforced Tier-2 remote flow that reaches High without physical presence (§18.1).

18.4 Reality check. Stage 3 is a long-horizon, politically-gated destination requiring Member State sponsorship and formal certification. This profile defines the technical conformance target; it does not assert a timeline. Stage 3 is the destination, not the entry point; most adoption begins at Stage 1.

18.5 Open strategic risk (informative). Beyond scheduling and certification, a prior question is unresolved: whether EU regulators and Member States will accept a *public, permissionless* ledger as the anchoring substrate of a notified identity scheme at all. The concerns are real and not purely technical: the data-protection optics of writing any per-identity commitment to a public chain (§15.3), the absence of a single accountable operator, and the governance and brand associations of the wider BSV ecosystem. The architecture mitigates the first (only blinded, pseudonymous commitments are written on-chain, confidentiality-protected rather than proven anonymous, §15.3, §20.4) but cannot mitigate the others by design. This risk is now evidenced, not hypothetical: at least one early Member State wallet pilot was abandoned in part because a stack relying on blockchain and zero-knowledge proofs did not meet baseline security requirements, notably protecting cryptographic material in certified secure hardware, and informed commentary expects advanced cryptography such as ZKP, and a fortiori public-ledger anchoring, to be admitted only at a later, more cautiously certified stage. The architecture's answer is on-device proving with secure-element key custody (§8) and only blinded commitments on-chain, but the burden of proof sits with this profile. This is a first-class strategic risk for Stage 3, distinct from the timeline; Stages 1-2 are deliberately structured to deliver value without depending on its resolution.

19. Format and trust interoperability: *Normative*

The cross-cutting mechanics that make Stages 1-3 work.

19.1 Credential-format mapping. The canonical internal model is the W3C VC, data model 2.0 (§11). Two corrections govern this section, both stated plainly because earlier drafts got them wrong. *First, the legal baseline:* the binding implementing acts require **PID** in **both** ISO/IEC 18013-5 **and** W3C VCDM 1.1 (CIR 2024/2977 Annex §4), whereas an electronic attestation of attributes (EAA/QEAA) must comply with **at least one** listed format, not categorically both (CIR 2024/2979 Annex II). **SD-JWT VC appears in no binding act**: it is specified by the ARF/HAIP profile layer, which evolves separately. A conforming bridge therefore MUST implement the act-baseline encodings (mdoc, and a normative **VCDM 2.0 → 1.1 issuance profile**: down-conversion of the canonical model to a 1.1-conformant credential, issued and signed as such), and MUST additionally implement SD-JWT VC for HAIP-conformant counterparties, SHOULD with ISO/IEC 18013-7 for remote mdoc. *Second, the mechanics:* an issuer-signed credential cannot be "exported" between these formats with its signature intact; each format signs its own encoding. Cross-format availability is achieved by **multi-format issuance** (the issuer signs each required encoding, per CIR 2024/2982), by issuer-mediated re-issuance, or by a separately signed wrapper whose trust chain is stated; a bridge MUST NOT present a re-encoded credential under the original signature's authority.

19.2 Protocols. Issuance MUST use OpenID4VCI and presentation MUST use **OpenID4VP 1.0 under HAIP 1.0** (both now final specifications), pinning the supported client-identification, request-signing, DCQL query, response-encryption, and verifier-attestation modes rather than leaving them open; ISO/IEC 18013-7 applies to remote mdoc flows. These are the EU-boundary mode of the dual-protocol presentation layer (§14); the BRC-103 mode is used only within the BSV ecosystem.

Format and protocol conformance, even with a qTSP relationship, does **not** by itself establish EUDI Wallet conformity. A full conformance profile must additionally address, as applicable: wallet-relying-party registration and access certificates; Wallet Unit Attestation and WSCD binding; transaction logging; user erasure-request and per-presentation approval interfaces; reporting of relying parties to supervisory authorities; alternative access for users who do not adopt a wallet; data separation and unobservability; and certification and vulnerability-management duties (§18.2). These MAY be phase-gated (§23), but a deployment MUST NOT imply that format support, OID4VCI/OID4VP, and a qTSP relationship alone constitute EUDI conformity.

19.3 Trust anchoring. EU trust is established through Registrar registration, access certificates, and Trusted Lists; BSV-native trust through the on-chain accredited-issuer registry (§15.6). The profile MUST

let a verifier resolve an attestation's trust by either path, and an on-chain registry entry SHOULD reference the corresponding Trusted List entry where one exists. Interoperability is credential-and-trust-list-level, not DID-method-level: a verifier in another ecosystem (e.g. EBSI/`did:ebsi`, a national eID scheme) trusts a presented attestation via its Trusted List or a bridge issuer, not by resolving the holder's `did:bsv` root in that ecosystem's method (§7.1). A deployment targeting such an ecosystem MUST state which bridge or cross-certification carries trust across the boundary.

19.4 Unlinkability reconciliation. The Regulation mandates unlinkability in principle: Recital 14 calls for integrating privacy-preserving technologies such as zero-knowledge proof, and the technical framework forbids any party from obtaining data that lets transactions be tracked, linked, or correlated without the user's authorisation. The ARF's own definition of full unlinkability (no party, including a provider colluding with a relying party, can tell that disclosed attributes describe the same user) coincides with the §10 goal. As of 2026 the ARF has acted on this: zero-knowledge proof is now a dedicated discussion topic with high-level requirements consolidated into Annex 2 (alongside a dedicated pseudonyms topic), referencing ETSI TR 119 476 and naming BBS+, the pairing-free ECDSA-compatible BBS#, zk-SNARKs, and ECDSA-based anonymous credentials. Two of those requirements are directly germane: a ZKP scheme is expected to generate proofs over PIDs and attestations *already issued* in ISO/IEC 18013-5 or SD-JWT VC form, and ZKP interactions MUST NOT enable tracking or linkability. Three caveats keep the gap real. First, deployment is deferred: ZKP support is expected only *after* the December 2026 launch, so the live baseline (SD-JWT VC, mdoc) is linkable and reaches verifier-unlinkability only by issuing single-use credentials in batches, at operational cost. Second, the ARF's leading ECDSA-compatible candidate, BBS#, requires per-presentation interaction with the issuer (linear scaling), whereas the §13 path supports offline, non-interactive unlinkable presentation. Third, the recent relaxation of device binding from mandatory to recommended eases anonymous-credential deployment but does not change the launch baseline. This profile therefore: (a) for the EU baseline path, emits ARF-compatible SD-JWT VC / mdoc, accepting their linkability or using batch issuance; and (b) offers the §13 Layer C/D zero-knowledge path as the privacy-preserving option aligned with Recital 14 and the Annex 2 ZKP requirements. Because those requirements describe proving over already-issued SD-JWT/mdoc credentials without linkability, this layer is positioned not merely as *ahead of* the EU baseline but as a candidate **conformant zero-knowledge presentation layer for ARF-issued credentials**, mapping onto the ARF ZKP track (BBS#/BBS+) as it is specified. Two caveats scope that claim. First, the ARF requirement literally describes proving over PIDs and attestations *already issued* as SD-JWT VC or mdoc (SHA-256 salted-disclosure structures under ECDSA signatures), and proving those formats inside a circuit is a substantially heavier statement than this design's enrolment-commitment circuit (§13.8). Second, the EU's own technical specification on ZKP (TS4) states that *no existing ZKP approach can be deemed fully suitable or mature enough for direct integration into the EUDI Wallet*, citing standardisation gaps, absent HSM/secure-element support for pairing-friendly curves, and issuer-interaction burdens. "Candidate conformant zero-knowledge presentation layer" is therefore **roadmap positioning, not a present conformance claim**: it is made for the BBS# track as the ARF specifies it, conditional on TS4′s maturity gates being met, with SD-JWT-VC/mdoc-in-circuit proving named as an explicit work item (§23, Phase 1) rather than an implied capability. The honest summary: the layer's zero-knowledge path delivers unlinkability from day one and offline; its baseline-format path inherits the same linkability as the EU baseline until the ARF zero-knowledge track is actually deployed, so the standing advantage is the day-one, non-interactive property rather than a permanent capability gap (§22).

19.5 Revocation reconciliation. The privacy-preserving accumulator (§13.5) MUST map onto the ARF Attestation Status List / Attestation Revocation List, or be replaced by short-lived (≤ 24-hour) attestations; unlinkable revocation under collusion remains an active research area and a candidate contribution.

19.6 Centralisation contrast (informative). The ARF relies on centralised trust anchors, government-issued identifiers, and registry-based relying-party lookup; the BSV layer offers a decentralised, on-chain-anchored trust substrate. At Stages 1-2 the layer conforms to the EU's centralised anchors at the boundary while retaining decentralised anchoring internally, a positioning point developed in §22.

19.7 Pseudonym reconciliation (CIR 2024/2979 / ARF Topic 11): ***Normative.*** The EU gives wallet pseudonyms a specific legal-technical meaning: Commission Implementing Regulation (EU) 2024/2979 Annex V designates W3C WebAuthn (Level 2) as the technical specification for pseudonym generation, and the ARF handles pseudonyms as Annex 2 Topic 11, which also develops scope-rate-limited pseudonyms whose cryptography is expected to be standardized by a recognised standardisation body. The scoped pseudonym `pid` (§10) is not a WebAuthn pseudonym, so a Stage-1/2 bridge MUST NOT claim that `pid` implements the CIR 2024/2979 pseudonym requirement. A conforming bridge runs dual-stack: WebAuthn-based pseudonyms for the EU legal obligation (aligning naturally with the §8.8 authenticator binding), and `pid` for the zero-knowledge path. Topic 11′s scope-rate-limited-pseudonym track is the potential convergence point for `pid` and SHOULD be tracked, noting that its standardisation-body requirement is not satisfied by a BRC alone.

Part V: Closing

20. Security and privacy considerations: *Normative (requirements); Informative (analysis)*

20.1 Threat model. The adversaries of concern are: colluding relying parties seeking to correlate a user; an issuer or attestation source colluding with relying parties; a network observer; a thief of a holder's keys or device; a holder attempting to present a stolen or copied credential; and a compromised trust anchor (a CSCA, an issuer/qTSP, or a ZK trusted setup).

20.2 Correlation and linkability. Cross-RP correlation is defeated by scoped pseudonyms and the zero-knowledge presentation (§§9-10, §13): even pooled relying-party data cannot link a user's pseudonyms. Issuer-RP collusion is mitigated because the issuer observes neither presentations nor status checks (§7.5, §15.4) and because a presentation can prove issuer-set membership without naming the issuer (§13.4). Two residual exposures remain and MUST be addressed at deployment: (i) network-level correlation (IP, timing, device fingerprint): the unlinkability guarantee of §§9-10 is *cryptographic* and does not extend to the network layer, where most practical deanonymisation occurs. It SHOULD be mitigated with transport-level measures: oblivious HTTP (OHTTP) or a mixnet / Tor-style relay to hide network origin, plus timing padding and batched submission; and a deployment MUST NOT represent its cryptographic unlinkability as network-level anonymity; and (ii) the linkability of the EU baseline formats when the SD-JWT/mdoc path is used instead of the ZK path (§19.4).

20.3 Key and device compromise. Root keys and the root secret MUST be held in a secure element wherever available. *Device loss with intact secure-element custody* is a recovery event, not an identity loss: keys rotate (§7.4), the device is revoked from the authorized-device list (§8.10), and pseudonyms, deriving from the personhood commitment rather than any signing key (§8.4), survive unchanged. *Root-secret exposure* is not contained by rotation: `s` derives from the root secret and cannot rotate without changing every pseudonym, so an attacker holding the secret retains derivation and correlation capability regardless of DID operations. That event is handled by the §8.10 compromise path (`s`-migration with per-relationship pid handover, gated on re-enrolment under the same registry tag) or avoided outright by threshold proving. Claiming rotation contains it, as an earlier draft did, was wrong.

20.4 Commitment confidentiality. Any on-chain commitment MUST be blinded with high-entropy salt so it cannot be brute-forced or dictionary-attacked back to its inputs. This matters most for the personhood nullifier `n`, which is recomputable by anyone who has read the passport chip and therefore MUST never be committed or published on-chain except as a salted, one-way value. The one value derived from `n` that is deliberately unsalted, the enrolment-registry uniqueness tag (§10.7), is for exactly that reason held **off-chain** by the registry operator set and never anchored (§15.3); it is a confidentially-held record field, not an exception to the on-chain blinding rule. The SOD-hash input to `n` (§8.4) makes it infeasible to dictionary-attack from photo-page data alone, but chip readers recompute it trivially;

genuine entropy comes only from the presentation secret `s` (§8.4). Treating `n` as if it were secret is the failure mode to avoid.

20.5 Replay and transfer. Presentation proofs MUST bind to a fresh, transcript-derived verifier challenge (§14.4), defeating both replay and relay. Non-transferability (§11.6) prevents a copied credential from being presented by another party. Because presentation authenticates cryptographic control of `s` and the holder key rather than a live biometric, the deepfake, face-spoof, and injection attacks that threaten biometric authentication systems do not reach the presentation path; biometrics appear only at Tier-2/3 enrolment (§12), never at each use. Zero-knowledge proofs in common systems (e.g. Groth16) are re-randomizable, since the same statement yields unlimited distinct valid proof encodings, so proof bytes MUST NOT be used as an identifier, deduplication key, or anti-replay handle by verifiers or overlay indexers; freshness comes from the §14.4 challenge, and account identity from the scoped pseudonym only.

20.6 Revocation freshness. Status checks have latency bounded by resolver/accumulator synchronisation; a revoked credential could be accepted within that window. Deployments MUST state an acceptable freshness window and SHOULD prefer short-lived attestations where the window must be tight (§17.3, §19.5).

20.7 Trust-anchor compromise. A compromised CSCA undermines Tier 1; a compromised issuer/qTSP undermines the credentials it signed; both are contained by accreditation and registry revocation (§15.6). A compromised ZK trusted setup could forge proofs; transparent-setup systems (Bulletproofs, STARKs) avoid this, and where a setup is required it MUST use a multi-party ceremony (§13.6).

20.8 Residual limits, stated plainly. Tier-1 binding is self-asserted: a lost or stolen passport could be self-read by another party, so Tier-1 personhood and uniqueness resist casual abuse, not determined impersonation (§§10.7, 12). The enrolment race is the sharp instance: whoever enrols a document first holds its registration, and Tier 1 cannot distinguish the rightful holder from a thief; the normative remedy is accountable eviction by a Tier-2/3 proofing event (§12), not adjudication at Tier 1. A party holding chip data can also test whether a document has enrolled at all, by recomputing the deterministic tag and querying the registry for it, but only with registry query access, since the tag is held off-chain, access-controlled and rate-limited (§10.7, §15.3); the residual leak is gated on that access, not open to any chip reader. And secp256k1 ECDSA/Schnorr are not post-quantum; migration is possible through DID key rotation (§7.4) as post-quantum signatures and proof systems mature, and is a tracked long-term item.

Unlinkability has an accountability cost, stated plainly. Cross-relying-party unlinkability (§10) is deliberate, and it means the protocol cannot trace a malicious actor *across* services: within one relying party a `pid` is stable and bannable, and Tier-1 registry uniqueness bounds a person to one active enrolment per document, but a determined abuser can present an uncorrelated `pid` at the next service, and a second lawful document (renewal or dual citizenship, §12) yields a fresh `n`. Accountable linkage exists only through explicit, scoped channels: per-RP `pid` banning, accountable Tier-2/3 eviction (§12, F.6), and, for regulated contexts, the delegated-CDD retrieval path (§10.10). The design deliberately provides **no** general cross-service de-anonymization. A deployment that needs lawful traceability for abuse outside the AML path (fraud rings, coordinated abuse, court-ordered disclosure) MUST add it explicitly as an *optional* mechanism (for example a linking key escrowed under a threshold of independent parties and openable only on documented due-process authorization), MUST disclose it to holders, and MUST NOT make it a silent default; equally, the *absence* of such a mechanism MUST NOT be represented as making the system immune to abuse. This tradeoff is one regulators will weigh directly (§18.5).

21. Reference implementation and conformance: *Normative*

21.1 Reference stack. A reference implementation SHOULD build on the existing BSV TypeScript stack: the SDK wallet client and BRC-103 authentication, BRC-52/53 certificates, the `did:bsv` resolver (overlay/Teranode-native, with WhatsOnChain as a driver, §7.6), and a pluggable zero-knowledge module exposing the §13 layers (Bulletproofs on secp256k1; BBS+/BBS# on their respective curves; a SNARK toolchain including the ICAO passport circuit).

21.2 Conformance vectors. The standard MUST publish test vectors for: ECDSA over secp256k1 (§8.1), the profile's sole signature scheme for chain operations and the BRC-103 handshake, and Schnorr over secp256k1 **only** where an implementation uses it for the optional in-circuit source-signature verification of §13.4(b) (§8.1 does not admit Schnorr for the handshake); type-42 derivation (§8.2); scoped-pseudonym PRF derivation (§10); the §10.3 presentation statement for each ZK layer, including enrolment-registry membership (positive and negative); canonical-range rejection of proof public inputs, where a verifier MUST reject any public signal outside the canonical field range, and the suite MUST include a negative (aliased) vector for it; date-of-birth and threshold canonicalization, including MRZ two-digit-year and Feb-29 edge vectors (the PoC document fixes the rules); the fixed domain-separation tag registry, including the permanent retirement of withdrawn tags; revocation-accumulator non-membership (§13.5); the C.6 anchor and locator derivations (`anchor_RP`, `ref_RP`) with a grant-verification fixture; the F.2 registration statement (a valid registration, plus negatives for stale challenge, cloned-chip/no-AA, tag mismatch, and algorithm-policy violation) and F.3 state-machine transitions including the concurrent-registration race; the pid-handover proof (§8.10); the self-issued-credential securing mechanism (ES256K VC-JOSE-COSE, §11.3); the complete `poseidon-commit-v1` specification vectors (C.4); and the VCDM 2.0⟶1.1 issuance-profile and mdoc mappings (§19.1). The suite MUST additionally assert the §20.5 prohibition: no conforming component may index or deduplicate by proof bytes.

21.3 Conformance suite. A multi-language conformance runner (at minimum TypeScript and Go, mirroring the existing BSV conformance framework) MUST validate an implementation against the vector corpus, and MUST include EU-boundary interoperability tests for OID4VCI/OID4VP under HAIP against the EUDI reference implementation and, where possible, a Large-Scale Pilot.

21.4 Reference flows. The implementation SHOULD demonstrate, end to end: Tier-1 self-read passport onboarding; a predicate-only presentation (over-18) with an unlinkable pseudonym; a Tier-2 issuer/QEAA issuance; and a Stage-1 bridge presentation to an EU relying party.

21.5 Openness. The specification, vectors, and reference implementation SHOULD be published openly within the BSV open-source ecosystem so that conformance is independently checkable.

22. Comparison: *Informative*

This layer is not the first digital-identity system; its contribution is the *combination* of native unlinkability, built-in tiered KYC anchored to a free self-read tier, decentralised on-chain trust, and eIDAS interoperability on one scalable chain.

Dimension	This proposal	EUDI-native	Sovrin / Indy (AnonCreds)	ION / Sidetree	Centralised IdP
Identifier anchoring	`did:bsv` on BSV (UTXO, SPV)	none; PKI + registries	permissioned ledger	`did:ion` (Bitcoin + off-chain store, batched)	account at provider
Unlinkability (multi-show / collusion)	native, collusion-resistant, day-one	baseline linkable; ZK post-launch / batch issuance	yes	n/a (identifier only)	none; provider sees all
Predicate / ZK proofs	yes (§13), offline	in ARF Annex 2; deployed post-launch	yes	no	no
Built-in KYC / personhood	yes; tiered, free self-read	yes; PID (government)	no	no	no
Trust-anchor decentralisation	on-chain registry	centralised	consortium	decentralised id, off-chain data	centralised
eIDAS interop / standing	yes (Part IV)	native	limited	limited	no
Scale & cost	high throughput, low fee	PKI-bound; issuer batch cost	consortium-limited	Bitcoin throughput; batched	high (centralised)

A few points the table compresses. The EUDI Wallet is the regulatory destination, not a competitor: this layer interoperates with it (Part IV); its standing advantage is unlinkability *from day one and offline*, where the ARF mandates the property and has now written high-level ZKP requirements into Annex 2 but defers their deployment to after the December 2026 launch (§19.4), which also makes this layer a candidate conformant ZK presentation layer for ARF-issued credentials rather than only a competitor (scoped as in §19.4: via the BBS# track, with SD-JWT/mdoc-in-circuit proving a named work item). Hyperledger Indy with AnonCreds pioneered unlinkable selective disclosure and predicate proofs and deserves that credit; the difference here is the ledger model (a permissioned validator consortium versus a public, high-throughput UTXO chain with SPV) and the addition of passport-anchored personhood and eIDAS interop. ION/Sidetree anchors decentralised identifiers on Bitcoin but is an identifier layer only, with DID documents kept in content-addressed storage (an availability dependency) and batched anchoring latency; this layer anchors directly and adds the credential, KYC, and zero-knowledge stack above the identifier. Centralised identity providers are convenient but make the provider a correlation point that sees every login (§14.6), hold the user's data, and carry no verifiable KYC or portability.

23. Roadmap and phasing: *Informative*

Delivery is phase-gated and aligned to the eIDAS calendar: national EU Digital Identity Wallets due by late December 2026 and mandatory relying-party acceptance (regulated sectors, very large online platforms) following roughly a year later, with real-world rollout lagging into 2027. Each phase has an explicit exit gate.

Phase 0, foundations. `did:bsv` resolution (overlay/Teranode-native), key management and recovery, BRC-103 and OID4VP presentation, the W3C VC model with multi-format SD-JWT VC issuance (§19.1), Tiers 0-1 (including free self-read passport onboarding), and Layer-A selective disclosure. Delivers the substrate, free document-authenticity onboarding (Tier 1, not regulatory KYC, which arrives with the accountable tiers, §12), and basic login; corresponds to the Stage-1 bridge. *Gate:* conformance vectors pass; security review of key handling and the self-read pipeline.

Phase 1, predicates and unlinkability. Zero-knowledge Layers B-D: range/predicate proofs, unlinkable presentation, the enrolment registry with membership proofs (§10.7), and the ICAO passport circuit. This is the privacy differentiator. It also carries the SD-JWT-VC/mdoc-in-circuit proving work item

(§19.4) toward ARF ZKP conformance. *Gate:* ZK audit (including any setup ceremony); unlinkability tested against pooled-RP collusion.

Phase 2, qualified interoperability. Stage 2 (QEAA via a qTSP), Trusted List mapping, mdoc and ISO/IEC 18013-7, full OID4VCI/VP HAIP conformance, and Tier-2 issuers. Timed to meet relying-party obligations. *Gate:* EU-boundary interop tests pass; a qTSP partnership in place.

Phase 3, national scale. Stage 3 (notified eID at LoA High, Tier 3, PID under Member State authority) and EUDI Wallet certification. Long-horizon and politically gated. *Gate:* certification and Member State sponsorship.

Beyond: organisational identity. Legal-person and organisational identity (out of scope here, §3) is future work, anchored on ISO 17442 LEI / GLEIF vLEI and bridged through the delegation model (§§9.4, 15.5).

24. Conclusion and appendices

Conclusion. BSV already holds the pieces of a national-grade identity system (type-42 keys, BRC-103 authentication, BRC-52/53 selective-disclosure certificates, and a registered, UTXO-friendly `did:bsv`), but they have stood as two unconnected stacks. This proposal binds them into one standard whose defining property is KYC that is private, verifiable, and unlinkable: a person proves they are a real, current, appropriately-assured human who meets a relying party's conditions, presents a different identifier to every service, and cannot be correlated across services even under collusion. Onboarding begins free, with a self-read passport, and rises through issuer-verified, in-person, and ultimately notified-eID assurance. The layer interoperates with eIDAS at every stage and is unlinkable by default from day one, where the EU has written zero-knowledge requirements into the ARF but defers them to after the December 2026 launch, positioning this layer as a candidate conformant ZK presentation layer for ARF-issued credentials (via the BBS# track, §19.4), not merely a competitor. The next steps are to publish it as a BRC and an eIDAS interoperability profile, build the open reference implementation and conformance suite (§21), and engage a qTSP and a Member State for the qualified and notified stages.

Appendix A: BRC reference.

BRC	Subject	Role here
1	Abstract messaging layer	carried certificate requests (BRC-53, historical)
2	Encryption	field encryption for keyrings
3	Digital signatures	certificate field signatures
42	Key derivation (type-42)	per-counterparty keys (§8)
43	Security levels, protocol/key IDs, counterparties	derivation addressing (§8)
52	Identity certificates	selective-disclosure certificates (§11)
53	Certificate creation and revelation	historical; superseded by the BRC-100 certificate methods (`acquireCertificate`, `listCertificates`, `proveCertificate`, `relinquishCertificate`), cited for lifecycle concepts (§11)
100	Wallet-to-application interface	wallet API substrate and the live certificate interface (§5.1, §11)
103	P2P mutual authentication & certificate exchange	BSV-native presentation (§14)
104	HTTP transport for BRC-103	`.well-known/auth` endpoint and `x-bsv-auth` headers; the web transport of §14
107	Mandala token protocol	base for identity-linked tokens
108	Identity-linked tokens	KYC/AML-gated assets (§5.1)

Appendix B: `did:bsv` profile, *Normative.*

This appendix consolidates §7 into a concrete profile over the registered `did:bsv` method [DID-BSV], W3C DID Core [DID-CORE], and W3C DID Resolution [DID-RES]. It adds requirements to the method; it does not redefine it.

B.1 Identifier syntax. A DID is `did:bsv:<method-specific-id>`, where the method-specific identifier is the hex-encoded transaction ID of the DID issuance transaction. Resolution decodes it from hex to the binary txid and follows the on-chain operation chain (B.5).

B.2 DID Document profile. The default is self-sovereign (subject is its own controller, §7.3); the document lists the holder's secp256k1 keys directly:

```
{
  "@context": ["https://www.w3.org/ns/did/v1"],
  "id": "did:bsv:<txid-hex>",
  "verificationMethod": [{
    "id": "did:bsv:<txid-hex>#subject-key",
    "type": "JsonWebKey2020",
    "controller": "did:bsv:<txid-hex>",
    "publicKeyJwk": { "kty": "EC", "crv": "secp256k1", "x": "...", "y": "..." }
  }],
  "authentication": ["did:bsv:<txid-hex>#subject-key"],
  "assertionMethod": ["did:bsv:<txid-hex>#subject-key"]
}
```

Requirements: - Every `verificationMethod` MUST be a secp256k1 key (`JsonWebKey2020` with `publicKeyJwk` `kty:"EC"`, `crv:"secp256k1"`), derived under §8. - `authentication` MUST be present

(BRC-103 handshake and presentation control). `assertionMethod` SHOULD be present where the DID acts as a credential issuer (Tier 2/3). `capabilityInvocation` / `capabilityDelegation` MAY express delegation (§9.4); `keyAgreement` MAY be present for keyring key-wrap. - The root DID Document MUST NOT carry attributes or services that identify the natural person: it is a control and recovery anchor, never a presentation identifier (§7.7, P12). `service` entries SHOULD be limited to control/recovery endpoints (e.g. `LinkedDomains`). - Multiple per-device signing keys MAY appear as distinct `verificationMethod` entries; this set **is** the authorized-device list of §8.10. De-authorizing a device is a DID Document update (B.4) that removes or expires its entry. Device keys are control keys, not person-identifying data, so listing them does not breach the preceding rule (§7.7). - In the non-SSI case a `controller` property names the controller's `did:bsv`, and the subject document lists the subject key while the controller is resolved separately, per [DID-BSV].

B.3 Control and the 1-of-2 / 2-of-2 arrangement (§7.3). Subject and controller each hold secp256k1 keys that sign DID transactions. Either party MAY unilaterally **deactivate** (1-of-2), and either MAY sign the preceding funding transaction of an update; but a new DID Document version, **including any key rotation**, MUST be signed by **both** subject and controller (2-of-2 update). There is no unilateral rotation: where the controller will not co-sign, the subject's only independent path is deactivation followed by a successor DID (§7.3). In SSI use the holder is both, holding both key pairs, so the 2-of-2 update is satisfied by one party.

B.4 Operations (§7.2, §7.4). - *Create*: two transactions: a DID issuance transaction and the first DID Document transaction. The issuance txid becomes the method-specific identifier. - *Update / rotate*: a funding transaction (either party) followed by a DID Document transaction (both parties). The DID is unchanged; superseded keys remain in history with their validity windows, so prior signatures stay verifiable (§7.4). Adding or removing a single device's `verificationMethod` (per-device authorization / de-authorization, §8.10) is an update of this form. - *Deactivate / revoke*: a revocation transaction spending the chain-tip UTXO, by either party. Each operation spends the prior state's UTXO-0, yielding an ordered, double-spend-protected, timestamped chain from which the current document is deterministically reconstructed.

B.5 Resolution (§7.6). Per [DID-BSV]: decode the method-specific id to a txid and make it current; fetch the transaction spending its UTXO-0; if that is a DID Document transaction whose own UTXO-0 is unspent, return it; if spent, make it current and repeat; a funding transaction is skipped (made current, repeat); a revocation transaction returns the last document with metadata `deactivated:true`. A `versionId` query selects a specific DID Document transaction by txid. Profile additions: - The resolver MUST verify the operation chain under SPV (§7.6, P11). - The normative resolution path MUST run over BSV-native infrastructure (overlay / Teranode). A public indexer (e.g. WhatsOnChain) MAY be a driver but MUST NOT be the sole trust or availability dependency. - Resolution metadata MUST express the block height at which status was determined, and SHOULD support caching with a freshness indicator.

B.6 Status (§7.5). `active` / `deactivated` is derived from the chain (a revocation transaction sets `deactivated`). A verifier MUST be able to determine status independently, without contacting the issuer or a DID manager (P8). DID status complements credential status (Appendix C.3): a deactivated root DID invalidates any presentation bound to it. On the presentation path this is enforced through the §10.6 active-root-DID accumulator (the root DID is not resolved per presentation), not by direct resolution.

B.7 Resolution result. A resolver returns a standard W3C result: `didDocument`; `didResolutionMetadata` (content type, any `error`, and the block height at which the chain was read); `didDocumentMetadata` (`created`, `updated`, `deactivated`, `versionId`, and, where known, `nextUpdate`).

B.8 §7 conformance map. 7.1 Adoption → B.1-B.2; 7.2 Operations → B.4; 7.3 Control → B.3; 7.4 Rotation/continuity → B.4; 7.5 Status/revocation → B.6; 7.6 Resolution → B.5, B.7; 7.7 Root-not-a-presentation-identifier → B.2 (no person-identifying data in the document).

References: [DID-BSV] the registered `did:bsv` method specification (TNG/Teranode); [DID-CORE] W3C Decentralized Identifiers (DIDs) v1.0; [DID-RES] W3C DID Resolution.

Appendix C: data schemas, *Normative (structure); Informative (examples).*

These are interoperability profiles over existing standards; exact wire encodings are finalised with the reference implementation (§21). References are listed at the end.

C.1 Credential / attestation (W3C VCDM 2.0 [VCDM2]). A credential is a W3C Verifiable Credential:

```
{
  "@context": [
    "https://www.w3.org/ns/credentials/v2",
    "https://bsvblockchain.org/ns/unified-identity/v1"
  ],
  "type": ["VerifiableCredential", "BsvIdentityCredential"],
  "issuer": "did:bsv:<issuer>",
  "validFrom": "2026-01-01T00:00:00Z",
  "validUntil": "2031-01-01T00:00:00Z",
  "credentialSubject": {
    "personhoodCommitment": {
      "commitment": "<single blinded commitment binding s, n, and the addressable
   attributes (C.4)>",
      "scheme": "poseidon-commit-v1"
    },
    "assurance": { "tier": 1, "loa": "low-indicative" },
    "claims": { "given_name": "...", "family_name": "...", "birthdate": "...",
                "age_over_18": true, "nationality": "..." }
  },
  "credentialSchema": { "id": "https://bsvblockchain.org/schema/identity/v1",
   "type": "JsonSchema" },
  "credentialStatus": { "...": "see C.3" },
  "evidence": [ { "...": "Tier-1 passive-auth record or Tier-2/3 proofing
   record" } ],
  "proof": { "...": "enveloping VC-JOSE-COSE proof (ES256K) where secured under
   a secp256k1 key — including self-issued Tier-1; a Data Integrity proof only
   where the securing key matches a standardized cryptosuite (e.g. a P-256
   boundary key); or carried in an SD encoding (C.2)" }
}
```

Requirements: a credential MUST commit to both `s` and `n` (§8.4, §11.1) in a single blinded commitment (C.4, §20.4); the tier/LoA MUST be a provable, verifiable attribute (§12); each claim MUST be individually addressable for selective disclosure or predicate proof (§11.2); `issuer` is a `did:bsv` for Tier 2/3, while a Tier-1 credential is self-issued and its `evidence` carries the ICAO 9303 passive-authentication record (DSC⟶CSCA chain, data-group hashes, the Document Security Object) in place of a third-party signature (§11.3); for Tier-1 self-issued credentials `credentialStatus` reduces to document validity, expiry, and any lost/stolen signal (no issuer revocation, §11.5).

C.2 Selective-disclosure encodings (§11.4). A credential MUST be expressible in at least one of: - *SD-JWT VC* [SD-JWT-VC] over SD-JWT [SD-JWT / RFC 9901]: media type `application/dc+sd-jwt` (earlier drafts `vc+sd-jwt`); `vct` carries the type (it is **not** selectively disclosable, so choose a value that leaks nothing, per the spec's data-minimisation note); `cnf` carries the holder key for Key Binding (KB-JWT); `status` points to a Token Status List (C.3); selectively-disclosable claims are salted digests (≥128-bit salt). This profile is linkable across colluding verifiers (§13 Layer A) and MUST NOT be the sole encoding where §10 unlinkability is required. - *ISO/IEC 18013-5 mdoc* [MDOC]: CBOR, namespaced data elements, a Mobile Security Object; proximity over NFC/BLE and remote over ISO/IEC 18013-7. - *BRC-52/53 keyrings*: per-field BRC-2 encryption and BRC-3 signatures revealed through a keyring, with UTXO-outpoint revocation (the BSV-native profile). Where §10 unlinkability is required, the credential MUST additionally be issuable in a Layer C/D form: a BBS+ credential, or a commitment a SNARK can consume (C.4).

C.3 Status and revocation. Two complementary layers. - *Interoperable status pointer.* Either a W3C Bitstring Status List entry [BSL], namely a `credentialStatus` of type `BitstringStatusListEntry`

with `statusPurpose` (`revocation`/`suspension`), `statusListIndex`, and `statusListCredential`, or, for SD-JWT/mdoc, a `status` claim referencing an IETF Token Status List [TSL]: a compressed bit array published as a signed Status List Token (JWT/CWT), giving herd anonymity (a verifier retrieves many statuses, so the issuer does not learn which credential was checked). Both reveal the issuer's aggregate revocations, and if fetched from the issuer they leak the timing of the check. - *Privacy-preserving accumulator (§13.5),* REQUIRED where the no-issuer-contact property (P8) and unlinkability are both needed:

```
{
  "accumulator": "did:bsv:<registry>#rev-2026",
  "anchorOutpoint": "<txid>:<vout>",
  "scheme": "merkle-sparse-v1 | rsa-acc-v1 | allosaur-v1",
  "revocationHandle": "<opaque, blinded>",
  "nonMembershipProof": "<zero-knowledge proof — presented, never stored>"
}
```

The published set MUST contain only opaque handles or nullifiers, never identifying data (P12). Anonymous, oblivious revocation checks are achievable with accumulator constructions of the AnonCreds / ALLOSAUR class. The current accumulator value is anchored on-chain or on an overlay. The **same accumulator construction** backs the active-root-DID set of §10.6: its members are commitments to active root-DID control keys, a `did:bsv` deactivation operation removes the corresponding member, and a presentation proves current membership without revealing which. The accountable updater, anchoring cadence, and witness-refresh and freshness parameters for the DID-status accumulator are a Phase-1 deliverable (§21.2, §23).

C.4 Personhood commitment, uniqueness tag, and pseudonym (§8.4, §10). - *Presentation secret* `s`: high-entropy (≥128-bit), wallet-generated, domain-separated; recovered via §8.6, never from a document. - *Personhood nullifier* `n` (the uniKey): `n = H_dst("bsv-personhood-n" ‖ canonical(passport_identity))`, a one-way hash over the canonicalised passport identity: document number, MRZ fields, and SOD hash (§8.4; deliberately no biometric data group). Deterministic, **not** secret, and never used at presentation. - *Commitment in the credential*: a single blinded commitment `C = Commit(s, attrs, n; salt)` (§20.4): Pedersen on the proof-system group, or Poseidon inside a SNARK circuit. `C` is the enrolment-registry leaf at Tier 1 (§10.7). The scheme identifier (`poseidon-commit-v1`, C.1) is a name, not yet a specification: before conformance vectors are cut it MUST be fully specified: exact field and curve, input encoding and canonicalisation, domain-separation tags (from the registry below), salt entropy (≥128-bit) and generation, the binding and hiding properties claimed with their assumptions, update/re-issuance authorization, and test vectors (§21.2; the PoC document carries the initial concrete instantiation on BN254). A tier upgrade re-attests by issuing a fresh `C` (new salt, updated assurance metadata) over the same `s` and `n`; the registry replaces the entry under the unchanged tag, so pseudonyms and uniqueness both persist (P6). Earlier drafts specified two separate commitments (`C_s`, `C_n`); the single-commitment form is normative, since it is what the presentation circuit opens and the registry stores, and dual-commitment encodings are non-conformant. - *Scoped pseudonym*: `pid = PRF_s(scope_RP)`. Exactly **one** PRF instantiation is canonical for `pid`: a SNARK-friendly PRF (Poseidon over the profile's proof field), used identically whether or not the presentation is proven in zero knowledge, with fixed field, input encoding, output size, and domain-separation tag pinned in the registry below and in the conformance vectors (§21.2). A single fixed instantiation is mandatory: `pid` must be reproducible across proof modes and across wallet implementations provisioned from the same root secret (§8.9), and must be openable in-circuit for the §8.10 pid-handover proof and the §10.3(f) membership statement. A wallet MUST NOT derive `pid` for one (`s`, `scope_RP`) pair by two different functions; the earlier "Poseidon where proven in zero knowledge, or HMAC-SHA-256 otherwise" choice is withdrawn as non-conformant, since it forks the account identifier across modes. `scope_RP` is the verifier's stable scope (§14.2). - *Enrolment uniqueness tag* (§10.7): `tag = PRF_n("bsv-uniqueness-tag")`, recorded once in the off-chain registration record held by the registry operator set (§10.7, §15.3); never anchored on-chain and never revealed at presentation. Deterministic and unsalted by construction (§15.3, §20.4). This replaces the withdrawn `gnull` global-set nullifier of earlier drafts, which was recom-

putable by chip readers and is prohibited (§8.4). - *Domain-separation registry*: every PRF/hash use MUST take its tag from a single published registry; the PoC document fixes the initial field-constant assignments and permanently retires the withdrawn presentation-nullifier tag. Each PRF/hash primitive, for `n`, for `tag`, and for `pid`, MUST be a **single fixed instantiation** (function, field, input canonicalisation, output encoding), so identical inputs yield byte-identical values across every conforming wallet and proof mode; cross-wallet uniqueness and pseudonym stability depend on it. Tags MUST keep `s`-derived pseudonyms and `n`-derived values in disjoint spaces, so pseudonyms are never derivable from `n` (§8.4). A retired tag MUST never be reassigned.

C.5 Consent receipt (ISO/IEC TS 27560:2023 [27560], building on ISO/IEC 29184 [29184] and Kantara CR v1.1 [KCR]; §15.1).

```
{
  "header": { "receiptId": "...", "timestamp": "...",
              "schema": "iso-27560:2023+dpv", "version": "1" },
  "parties": {
    "controller": { "id": "did:bsv:<rp>", "name": "...",
                    "accreditation": "<Trusted List reference>" },
    "principal": { "pseudonym": "<pid>" }
  },
  "consent": {
    "purposes": ["age-verification"],
    "disclosed": ["age_over_18"],
    "holderApproval": true,
    "legalBasis": "consent | contract | legal-obligation | legitimate-interests |
   public-task | vital-interests",
    "article9Condition": "explicit-consent | ... | none",
    "processing": ["use"],
    "retention": "P0D",
    "rightsAndExceptions": "<Art. 17(3) / statutory-retention notes, where
   applicable>",
    "collectionMethod": "oid4vp | brc-103"
  },
  "status": { "state": "active | withdrawn", "updated": "..." }
}
```

The principal is identified **only** by the scoped pseudonym `pid`, never the root identity (§7.7). The receipt MAY be hash-anchored on-chain for non-repudiation, recording only a salted commitment to the receipt and never its contents (§15.1, P12). Withdrawal sets `status.state` to `withdrawn` and triggers the deletion obligation (§15.3), subject, where §10.10 applies, to the lawful-basis override, which the receipt encodes as a `legalHold` entry (C.6). Field semantics SHOULD use the Data Privacy Vocabulary [DPV] for interoperability.

C.6 Delegated CDD custody: anchor derivation and retrieval grant (§10.10, §15.5).

Record key and per-relationship derivations. At enrolment the wallet and custodian establish the record key `k_rec` (an ECDH-derived shared secret over their enrolment keys, or a wallet-generated key delivered inside the Phase-1 full-disclosure session), and the wallet registers a **grant-verification key** with the custodian: a dedicated key derived under §8.2 (never the root controller key), whose sole purpose is signing retrieval grants for this record. Per relying party: - `ref_RP = PRF(k_rec, H_dst("bsv-cdd-ref" ‖ scope_RP))`, the opaque locator. Uncorrelatable across companies; resolvable by no one but the custodian. - `anchor_RP = Commit(digest(R); salt_RP)`, where `digest(R)` is a canonical hash of the record at issuance schema-version, `salt_RP` fresh high-entropy per relationship (§20.4). Opened at retrieval by releasing `R` and `salt_RP`. - Domain-separation strings here join the single tag registry (C.4); circuits never consume these values, so HMAC-SHA-256 is an acceptable PRF instantiation.

Retrieval grant. A delegation credential (§15.5):

```
{
```

```
  "@context": [
    "https://www.w3.org/ns/credentials/v2",
    "https://bsvblockchain.org/ns/unified-identity/v1"
  ],
  "type": ["VerifiableCredential", "CddRetrievalGrant"],
  "issuer": "<holder grant-verification key (enrolment-bound; never the root
   DID)>",
  "validFrom": "...",
  "credentialSubject": {
    "audience": "<company verifier key>",
    "ref": "<ref_RP>",
    "anchor": "<anchor_RP>",
    "custodian": { "endpoint": "...", "key": "<custodian key>" },
    "resolution": "<sealed to custodian key: { record_id, scope_RP, salt_RP,
                   enrolment binding: sig over grant hash by the registered
                   grant-verification key }>",
    "triggers": ["regulatory-demand", "sar-escalation", "statutory-production"],
    "legalHold": { "basis": "aml-record-keeping",
                  "retention": "P5Y-post-relationship",
                  "note": "revocation blocks new voluntary release only (§15.3,
   §15.5)" },
    "keyShare": "<wrapped 2-of-3 share for the company (§10.10)>"
  },
  "credentialStatus": { "...": "grant revocation, checkable by the custodian at
   retrieval (C.3)" },
  "proof": { "...": "signature by the grant-verification key" }
}
```

Requirements: the grant MUST NOT contain `pid`, the root DID, or any holder attribute; `audience` binding MUST be enforced by the custodian (release only over a mutually authenticated session with the named key, §14.4); the `resolution` capability MUST be opaque to the company; the custodian MUST verify the enrolment binding inside `resolution` against its registered grant-verification key, the presented trigger evidence, and, for voluntary triggers only, the grant's `credentialStatus` before release (a compelled trigger releases regardless of revocation, §10.10 Phase 4); and the disclosure event MUST be logged for audit, appended to the consent receipt only where it is not a tipping-off event, otherwise recorded solely in the confidential regulatory audit log (§10.10 Phase 4, AMLR Art. 73), and MAY be hash-anchored (P12). The `custodian` field is visible to the company by necessity (routing); it stays outside the §10.3 proof transcript, so the custodian's identity is not provable to third parties from the onboarding evidence (§10.10 Phase 2).

References: [VCDM2] W3C Verifiable Credentials Data Model 2.0 (Recommendation, 2025-05-15); [SD-JWT-VC] IETF SD-JWT VC (draft-ietf-oauth-sd-jwt-vc); [SD-JWT] RFC 9901 (Selective Disclosure for JWTs); [MDOC] ISO/IEC 18013-5 and 18013-7; [BSL] W3C Bitstring Status List v1.0 (Recommendation, 2025-05-15); [TSL] IETF OAuth Token Status List (draft-ietf-oauth-status-list); [27560] ISO/IEC TS 27560:2023; [29184] ISO/IEC 29184:2020; [KCR] Kantara Consent Receipt v1.1; [DPV] Data Privacy Vocabulary. Commitment, PRF, and accumulator constructions follow standard cryptographic literature (Pedersen commitments; Poseidon; AnonCreds; ALLOSAUR).

Appendix D: glossary.

- *Accumulator*: a compact set representation supporting (non-)membership proofs; used for privacy-preserving revocation (§13.5).
- *BBS+ / BBS#*: anonymous-credential signature schemes giving multi-show unlinkable selective disclosure; BBS+ needs pairing-friendly curves, BBS# is pairing-free and ECDSA-compatible.
- *CDD custodian*: an accredited Tier-2/3 entity holding customer-due-diligence records under split-key custody on behalf of AML-obliged relying parties; a distinct accreditation class (§10.10, §15.6).

- *CDD retrieval grant*: a holder-signed, audience-bound, revocable delegation credential authorizing a custodian to release the CDD record to a specific relying party on lawful triggers; carries a custodian-sealed resolution capability and the §15.3 lawful-basis override (§10.10, §15.5, C.6).
- *Per-relationship anchor*: `anchor_RP = Commit(digest(R); salt_RP)` with locator `ref_RP = PRF(k_rec, scope_RP)`: a per-RP, uncorrelatable cryptographic pointer to a custodied CDD record, opened only at lawful retrieval (§10.10, C.6).
- *DTC (ICAO Digital Travel Credential)*: the digital form of an eMRTD; Type 1 is holder-generated from the chip (≈ Tier 1), Type 2/3 are issuer-generated (≈ Tier 2/3) (§12).
- *FIDO2 / WebAuthn / CTAP*: phishing-resistant authenticator standards; an optional custody layer that raises NIST AAL independently of the proofing tier (§8.8).
- *HAIP*: High Assurance Interoperability Profile for OID4VCI/OID4VP.
- *IAL / AAL / FAL*: NIST SP 800-63-4 assurance dimensions (identity proofing, authenticator strength, federation), selected independently; only IAL maps to the tier (§12).
- *ICAO 9303 / passive authentication*: the electronic-passport standard, and the verification that chip data is genuine via the issuing state's PKI.
- *LEI / vLEI*: ISO 17442 Legal Entity Identifier and its GLEIF verifiable-credential form; the intended anchor for future organisational identity (§3, §23).
- *LoA*: eIDAS level of assurance: Low, Substantial, High.
- *mdoc*: the ISO/IEC 18013-5 mobile-document credential format (CBOR).
- *Scoped pseudonym*: `pid = PRF(s, scope)`; stable per scope, unlinkable across scopes (§10).
- *Personhood nullifier `n` (uniKey)*: a deterministic, one-way, passport-derived value (document number, MRZ, SOD hash) anchoring registry-wide per-document uniqueness at enrolment; not a secret, and never surfaced at presentation (§8.4, §10.7).
- *Enrolment registry / uniqueness tag*: the multi-party registry of active personhood commitments, admitting one active registration per deterministic tag `PRF_n(dst)`; the tag is held off-chain (only salted roots are anchored, §10.7, §15.3), the state machine is Appendix F, and presentations prove membership without revealing the entry.
- *OID4VCI / OID4VP*: OpenID for Verifiable Credential Issuance / Presentation.
- *PID / QEAA / EAA*: Person Identification Data; Qualified Electronic Attestation of Attributes; Electronic Attestation of Attributes.
- *Personhood commitment*: a credential's single blinded commitment binding two values: the wallet-held presentation secret `s` (source of pseudonyms and holder binding) and the passport-derived nullifier `n` (the uniKey, anchor of uniqueness) (§8.4, §10, C.4).
- *qTSP*: qualified trust service provider.
- *SD-JWT VC*: the selective-disclosure JWT verifiable-credential format.
- *Trusted List*: the eIDAS register of supervised and qualified providers.

Appendix E: conformance vectors. Index of the published test vectors (§21.2). *(To accompany the reference implementation.)*

Appendix F: enrolment-registry state machine, *Normative*.

The registry of §10.7 is not a passive index: it is where document-level uniqueness is enforced, and its behaviour under concurrency, disputes, and failure is part of the security argument. This appendix specifies it. One state machine exists per uniqueness tag.

F.1 States and what is retained. A record moves `unregistered` → `pending` → `active`, with terminal states `superseded`, `evicted`, `expired`, `revoked`. At most one `pending`-or-`active` record exists per tag at any time. A `superseded` (or `evicted`) record is retired **only as part of the same atomic transition that installs its successor** (F.3, F.4), so a supersession or eviction never leaves the tag without a live registration. Two structures must be distinguished: - The append-only operation log (F.5) keys each transition by an **opaque per-record identifier**, never by the tag. Log reconstruction, duplicate-transition detection, and misbehaviour proofs therefore do not require retaining the tag. - A separate tag→record **index**, the queryable structure that enforces one-active-registration-per-tag, exists only while the tag has a `pending` or `active` record.

When a tag reaches a state with no `pending` or `active` record (its last live record having `expired`, or gone `revoked` with no re-registration; eviction is atomic with winner-install per F.3 and so never empties the tag), the tag index entry is erased and only opaque record hashes and transition entries remain for auditability; the tag itself ceases to be queryable (§10.7, §15.3). A tag with a live successor stays queryable, because a successor record still occupies it; this is why a routine tier upgrade or `s`-migration (both `superseded` transitions) does not erase the tag.

F.2 The registration statement (Layer D). A registration proof MUST bind, in a single sound statement: - (a) *passive authentication*: the Document Security Object signature and data-group hashes verify against the accepted DSC/CSCA set expressed as the published trust root (§12), under an explicit **algorithm policy** (accepted signature suites and hash functions, including the legacy-algorithm cut-off) and **time policy** (certificate validity evaluated at an enrolment time carried as a public input); - (b) *chip freshness*: a fresh **Active Authentication** signature over a value derived from the registration challenge (f), **or** a fresh **Chip Authentication** authenticated-key-establishment transcript that binds that challenge-derived value. AA and CA are distinct ICAO protocols with distinct transcripts: CA is an authenticated key agreement establishing secure messaging, not a signature over an arbitrary nonce, so the statement MUST verify the protocol-correct transcript for whichever the chip supports. Verified in-statement wherever the document supports AA/CA (§12); where it does not, the record MUST carry `uniqueness: none` and no personhood guarantee attaches, though the one-per-tag rule still applies. A successful transcript demonstrates possession of the chip's authentication key under two stated assumptions: that the key was not extracted from the chip, and that the read was not relayed from a remote genuine chip (a proximity or channel assumption the deployment MUST state); it resists copied chip data and software emulation, not an adversary relaying a live foreign chip; - (c) *canonical derivation*: `n` derived from the chip data exactly per §8.4/C.4, and `tag = PRF_n(uniqueness_dst)`; - (d) *commitment consistency*: `C = Commit(s, attrs, n; salt)` over the **same** `n` and the same hidden attributes the passive-authentication statement validated; - (e) *record binding*: the `tag` and `C` in the submitted registration record are the values constrained in (c) and (d); - (f) *registration challenge*: a fresh, single-use, time-boxed challenge issued by the registry for this attempt, bound into the statement and bound to the submitting wallet's session transcript (§14.4), so the proof can neither be replayed nor hijacked into another party's submission.

A statement covering only passive authentication, as the Layer-D sketch in earlier drafts did, is insufficient wherever uniqueness is claimed, because passive authentication cannot detect a cloned chip (§12).

F.3 Transitions and authorization.

From → To	Trigger	Authorized by
`unregistered` → `pending`	registration submission	holder wallet: valid F.2 proof + live challenge
`pending` → `active`	operator-set validation and log append	registry operator quorum, **execution only**; operators MUST NOT originate registrations
`pending` → `unregistered`	proof invalid, challenge expired, or tag collision with an existing `pending`/`active` record	automatic
`active` → `superseded` *(atomic with install of the successor `active` record)*	replacement under the same tag (tier upgrade §12/C.4; `s`-migration §8.10)	holder: fresh F.2 proof over the same document **and** proof of opening of the incumbent `C` (or control of its bound holder key), i.e. continuity with the existing registration
`active` → `evicted` *(atomic with install of the winner's `active` record)*	accountable Tier-2/3 proofing over the same document (§12)	the evicting accredited issuer/qTSP, with an evidence reference logged; the verified holder's commitment is installed in the **same** transition
`active` → `expired`	document validity end (expiry from record metadata)	automatic
`active` → `revoked`	holder-initiated de-registration	holder: proof of opening of `C` (or the bound holder key) **and**, where the document supports AA/CA, a fresh chip-freshness transcript (F.2(b))
`revoked` → `pending`	re-registration of the same document after voluntary de-registration	holder wallet: valid F.2 proof + live challenge

Three properties of this table are load-bearing and were absent from earlier drafts:

- *No displacement by bare possession.* The `superseded` transition requires **both** a fresh F.2 proof over the document **and** proof of continuity with the incumbent registration (opening `C` or controlling its holder key). A party who has only handled the passport chip cannot open the incumbent `C`; a party who has only compromised the wallet cannot, for an AA/CA document, produce the fresh chip transcript F.2(b) requires. Neither can therefore supersede a rightful holder's active registration.
- *No irreversible malicious revocation.* Because `active` → `revoked` additionally requires a fresh chip transcript wherever the document supports AA/CA, a wallet-compromise attacker lacking the physical passport cannot revoke an AA/CA registration; and `revoked` is not a dead end: the rightful holder re-registers the same physical document via `revoked` → `pending`. Key compromise thus cannot be escalated into unrecoverable loss of the tag. For documents without AA/CA (`uniqueness: none`), the registry offers no anti-theft guarantee at all and recovery relies solely on accountable Tier-2/3 eviction (§8.10, §12).
- *Winner-install has a path.* Eviction and the winner's activation are a **single atomic transition**: `active` → `evicted` retires the squatter's record while the Tier-2/3-verified holder's commitment is installed as the new `active` record, so §12′s "evict and install" is realisable and the tag is never left unregistered for the rightful holder. An evicted party cannot re-enter the tag: the only entry into an evicted tag is the winner-install carried inside the eviction transition itself (there is no `evicted` → `pending`).

Eviction is the only transition a party other than the holder or the clock can cause, and it MUST carry the evidence reference and the evicting party's accreditation identity so it is contestable (F.6).

F.4 Concurrency and atomicity. Registration attempts are serialized by the registry's append-only operation log: among concurrent submissions for one tag, the first log-ordered valid submission wins

and later ones fail the collision check. The challenge (F.2(f)) provides *freshness and replay resistance* (it is spent by the transition, cannot authorize a second submission, and expires if the transition does not complete), but it does **not** by itself make a distributed state transition atomic; atomicity is a property of the registry's commit protocol (F.5), not of the challenge. Each transition that both retires an outgoing record and installs an incoming one MUST be committed as a **single atomic operation**, `Replace(tag, old_C, new_C, proof, challenge)` for supersession and `EvictAndInstall(tag, evicted_C, winner_C, evidence)` for eviction, so that no fork, crash, or partial replication can leave a tag with no `active` record or with two. There is no reachable state in which two `active` records share a tag; an operator set that appends one anyway has provably misbehaved (F.5).

F.5 Log, checkpoints, rollback, and forks. Registry state is a deterministic function of the append-only operation log. The operator set MUST be multi-party; a transition enters the log only with the defined quorum's signatures, and every log entry is attributable, so any observer of the log can prove an unauthorized or duplicate transition from the log alone; remedy (removal, slashing) is a trust-framework matter (§15.6). The current root over active commitments, with the log head, is anchored on-chain at a stated cadence (§10.7: roots on-chain, records off-chain). A chain reorganization deeper than the last checkpoint rolls the *anchor* back, not the log: the overlay re-anchors, and verifiers MUST treat roots younger than a stated finality depth as provisional, per their staleness policy (PoC §10). Divergent operator behaviour (a log fork) is resolved in favour of the longest quorum-signed prefix; conflicting quorum signatures on the same height are themselves proof of misbehaviour.

This is a fork-choice and accountability sketch, not yet a complete Byzantine-fault-tolerant replicated-state-machine specification, and the uniqueness guarantee rests entirely on it. Before the registry is relied on for a uniqueness claim, a deployment MUST pin the missing parameters: the operator population and maximum Byzantine fault count `f`; the quorum threshold and its intersection requirement (as `n`, `f`, and the required signature count); a height/view/epoch model with leader-failure and view-change behaviour; operator admission, removal, and signing-key rotation; equivocation handling and the effect of conflicting quorum certificates; a **precise finality point** (the longest-quorum-signed-prefix rule above is fork-choice, not finality); and data-availability and censorship expectations for the log and membership witnesses. A conforming deployment MUST do one of: **(a)** profile a named BFT consensus construction with all of these set explicitly; or **(b)** operate a **single accountable registry controller**, treating the multi-party operator set as an authorization and audit control rather than a decentralized-consensus claim, and disclose that trust assumption to relying parties. Option (b) is the honest default until (a) is specified; a deployment MUST NOT describe the registry as decentralized-consensus-backed while relying on (b).

F.6 Appeals and malicious first enrolment. A party contesting a registration, the stolen- or pre-read-passport race of §20.8, files a dispute record referencing the tag's current entry. The registry never adjudicates identity: adjudication is the Tier-2/3 accountable-proofing path (§12), and its outcome is the `evicted` transition (or the dispute lapsing after a stated window). Dispute and eviction records MUST NOT contain PII and MUST be auditable. An evicted party's relying-party relationships do not transfer (its `s` remains its own); the winning party's fresh credential supports pid handover only for pseudonyms derived from a secret *it* knows (§8.10).

F.7 Witness maintenance. Every transition changes the anchored root and invalidates cached membership paths; wallets refresh paths under the retrieval-privacy rules (PoC §10). Verifier staleness policy bounds how long a superseded root is accepted, trading revocation latency against refresh traffic (§20.6).